Substantiate, Don’t Assume

Why the Auditor’s Opinion Matters More Than Ever in the Age of AI

Michael Borck

2026-11-07

Substantiate, Don't Assume
Why the Auditor's Opinion Matters More Than Ever in the Age of AI

Copyright © 2025 Michael Borck.

Book content: Creative Commons Attribution 4.0 International (CC BY 4.0 International).
https://creativecommons.org/licenses/by/4.0/

Original code examples and accompanying software: MIT License.
https://opensource.org/licenses/MIT

These grants cover material the author has authority to license. Separately credited third-party material retains its stated terms.

Published by Michael Borck
Perth, Western Australia

ISBN: (to be assigned)

Case edition SDA-2026.1, revised September 2026. Worked engagement cutoff: 30 June 2026. Not yet published through KDP.

AI disclosure: AI tools supported drafting and revision. The author is responsible for reviewing and approving the published work. Case records and unattributed audit vignettes are fictional teaching examples, not actual client evidence.

Companion website:
https://michael-borck.github.io/substantiate-dont-assume
Source:
https://github.com/michael-borck/substantiate-dont-assume

Table of contents

Introduction: The Audit Mindset 1

I Act I · Engage: Build the Case **7**

1 Why? The Auditor's Mandate and Ethics 9

2 Risk? Foundations of Risk Management 17

3 Which? Frameworks and Standards 29

4 Scope? Audit Planning and Methodology 41

5 Expect? Technical Control Objectives 49

6 Assess? Physical, People, and ISMS Controls: Preliminary Readiness 59

II Act II · Prove: From Suspicion to Proof **67**

7 Prove? Evidence Collection and Testing 69

8 Comply? Policy Evaluation: From Published to Proven 77

9 Protect? Data Protection and Privacy 83

10 Recover? Business Continuity and Incident Management 91

11 Report? Findings and the Audit Opinion 101

12 Conclude? Certification, Defence, and the Future of Audit 111

Appendices **119**

A The Drafter-to-Evaluator Loop 119

B Fixed case pack: SDA-2026.1 123

C Answer checks and assessment 137
D Source guide and edition boundaries 145
E Interview guide and optional live practice 149
Acknowledgments 153
About the Author 155

Introduction: The Audit Mindset

Every organisation claims its information is secure. The auditor's job is to find out whether that claim survives contact with evidence.

The polished policy and the unpatched server

Visit a company's security page and you will find confident assertions: certification, encryption, careful handling of customer data. Those claims might be well supported. An auditor's task is to establish what they mean, what they cover, and what evidence supports them.

This book follows Tessera, a fictional Perth software company seeking ISO/IEC 27001 certification. Its CTO expects a straightforward sign-off. You have been asked for a readiness assessment. Neither the CTO's confidence nor your suspicion settles the result.

What information security auditing actually is

Information security auditing systematically evaluates evidence against agreed criteria. Those criteria may include a management-system standard, applicable law, contractual promises and the organisation's own policies. Authorised penetration testing and continuous monitoring can contribute evidence; they serve different purposes from an audit.

An **opinion** brings the findings together into a bounded judgement. It names the subject, criteria, period, methods and limitations. A readiness assessment advises an organisation preparing for certification. It does not award a certificate or replace the certification body's independent decision.

Trust, but verify

Professional scepticism means testing a claim fairly. Ask what would support it and what would contradict it. A nervous engineer may operate a sound control; a confident executive may have good evidence. Demeanour helps you plan a conversation, but does not determine your finding.

A productive engagement needs cooperation. Agree access and timing, explain requests, protect confidential material and give people an opportunity to correct factual errors. Independence still requires you to report an unwelcome result when the evidence supports it.

A snapshot, not a guarantee

An opinion provides bounded assurance about its subject and period. Sampling, incomplete records and changing systems limit what it can establish. It guarantees neither the past nor the future. Another competent reviewer should be able to follow your reasoning and identify where a different judgement could be defensible.

Substantiate, don't assume

A policy is evidence of a stated requirement or design. An operating record can support a claim about performance over time. Observation can show a control running at a particular moment. Each has limits; none becomes universally reliable merely because you collected it yourself.

Throughout the book, keep this trail in your working papers:

criterion □ evidence □ test □ result □ finding □ action □ retest □ opinion.

"Insufficient evidence" is a legitimate result. So is clearing a concern after a test passes. You are not rewarded for producing the greatest number of failures.

The auditor's work with AI

AI can help draft procedures, suggest questions and compare a finding with its evidence. Performance varies with the model, task and inputs. Fluent output can contain unsupported mappings, mistaken calculations or invented closure claims.

Use the drafter-to-evaluator loop when it helps: define the task, supply permitted inputs, check the draft against the record, and retain the corrections and limits. You remain responsible for the work. There is no requirement to find a model error if its answer is sound.

> ⚠ Watch out: your own AI hygiene
>
> Use only the explicitly fictional book exercises with unapproved tools. For real engagements, obtain authority for the tool, data and processing arrangement before use. Enterprise branding or local hosting alone does not establish confidentiality, retention, access control or legal compliance. Do not upload client evidence, credentials, personal data or licensed standards without the necessary permissions.

Who this book is for

This is a first audit engagement for readers with basic security knowledge: accounts and permissions, logs, backups, and the idea that a cloud provider and its customer have different responsibilities. The book explains technical terms when they become relevant. No CISA credential, purchased lab or prior reading of the companion

books is required.

By the end, you should be able to define a bounded engagement, select criteria, test supplied records, distinguish an observed exception rate from future incident likelihood, write a supported finding and defend a readiness conclusion.

This is teaching material, not legal advice or a replacement for authorised copies of standards. The book supplies original case criteria so that you can complete the exercises without purchasing a standard. A real engagement requires its agreed editions and suitably qualified review.

How this book works

Twelve chapters retain the engagement's progression from **Why?** to **Conclude?**.

Act	Chapters	Observable outcome
I · Engage	1–6	A mandate, criteria map and test programme that distinguish design evidence from untested operating claims
II · Prove	7–12	Reproducible working papers, a finding and closure ledger, and an opinion with explicit limitations

The act break stages the release of information for learning. In practice, interviews, document review and operational testing overlap. Remote examination of logs can be operating-effectiveness

work. “Full access” never means unlimited authority or complete assurance.

The **Evidence Locker** is your cumulative file. Use paper, a text document or a spreadsheet. Each chapter supplies one timed task and a checkable output. The case pack contains the fixed inputs; the answer checks should be read after an attempt. No AI account, code execution or live interview is needed for the core route.

The fixed case and the companion site

The canonical worked engagement is **SDA-2026.1**, a book-only Tessera teaching scenario, with a final evidence cutoff of **30 June 2026**. The appendix supplies original synthetic records, not exports or quotations from the live site. Its dates, contracts and test populations govern this book’s answers. The case is deliberately small and cannot establish an actual company’s conformance.

Tessera’s live companion site (https://tessera.locoensayo.org) remains an optional interview and discovery environment. It may describe a different date, certification status, contract or recovery target. Treat it as a separate exercise: record the page, retrieval date and your evidence, and do not splice changing website facts into the fixed case. Chatbot replies are simulated testimony, not verified records. Availability and answers can vary.

If you find drift within this book, report the edition, evidence ID and conflicting passages through the source repository (https://github.com/michael-borck/substantiate-dont-assume). No site content needs to be copied to complete the exercises.

The companion book

Conversation, Not Delegation (https://michael-borck.github.io/conversation-not-delegation/) develops the craft of working with AI. It is optional further reading. This book supplies its own method and practice inputs.

The series trunk is *Conversation, Not Delegation* for method and *The Human Edge* for professional judgement. This book is the branch for assurance and audit.

Conventions used in this book

 Tessera Case marks a worked example. **Evidence Locker** identifies the task and the output to retain. **AI Field Note** shows a bounded illustrative draft and its evaluation; it is not a transcript of a measured model run. **Auditing AI** applies assurance methods to AI-supported systems.

Three chapters retain extended **Take it to the AI** activities. Other chapters use inspection, calculation, comparison or short written decisions. All have a solo route. Case dialogue and revised third-person audit vignettes are fictional teaching examples.

How this book was written

AI tools supported drafting and revision. The author is responsible for checking and approving the published work. Source tests can catch arithmetic and continuity errors, but do not replace expert review or an unfamiliar reader's attempt.

Edition and review status

All twelve chapters are drafted. This revision targets ISO/IEC 27001:2022 with its 2024 amendment and NIST CSF 2.0. Guidance editions and primary references are dated in the source guide. The online edition may be updated separately from downloaded or printed copies; check their edition information. KDP publication, human proofing and fresh-reader testing are separate release gates.

Part I

Act I · Engage: Build the Case

Chapter 1

Why? The Auditor's Mandate and Ethics

> *Why does Tessera need an audit, and why should they trust you?*

Tessera Case: The engagement opens

The email arrives on a Monday. Tessera's CTO, racing toward an enterprise deal that requires ISO/IEC 27001 certification, has engaged your firm for a certification-readiness audit. The tone is confident: "We're pretty much there, we just need the paperwork signed off." That sentence records management's expectation. It is not evidence that controls work or fail. Ask what assessment supports it, and keep both possibilities open. Your engagement opens with a question, not an answer: *why does Tessera need this audit, and why should they trust the person delivering the opinion?*

1.1 The auditor's mandate

An auditor does not audit by accident. You audit because someone with the authority to ask for assurance has engaged you to provide it, on agreed terms, against agreed criteria. That is the mandate, and it has three parts that matter from day one.

You are engaged by a party that wants the opinion. In Tessera's case, that is a board and a CTO chasing certification. You audit **against criteria**: a standard or framework that defines what "good" looks like, here ISO/IEC 27001:2022. And you deliver an **opinion** on whether the subject matter (Tessera's information security management system) conforms to those criteria, supported by evidence you gathered on terms you set.

The mandate does not license you to poke around wherever you like, and it does not guarantee that you will find wrongdoing. It is a scoped, criteria-bound engagement whose entire value rests on one quality you bring to it: the credibility of the person giving the opinion. That credibility has a name, and it is the rest of this chapter.

1.2 Three hats: counsellor, partner, investigator

Auditors wear three hats, sometimes in the same meeting, and the skill is knowing which one the moment needs.

The **counsellor** helps the organisation understand its obligations before an opinion is formed. A client asks, "Do we really need separate incident-response and business-continuity plans?" You explain the standard, the intent, and the trade-offs. You are advising, not judging, and you must remember the difference, because advice given today shapes the evidence you evaluate tomorrow.

The **partner** works *with* the organisation to make the audit productive. You coordinate access, agree a realistic programme, and treat Tessera's staff as people running a business, not suspects to be interrogated. Most audits fail on logistics, not on findings.

The **investigator** is the hat people picture: following the evidence where it leads, asking the uncomfortable question, refusing to accept "we do that" without proof. This is where professional scepticism lives, and it is the hat this book spends the most time on.

The three hats share one requirement: whichever you wear, your

judgement has to be yours, and it has to be defensible. That brings us to the foundation the whole profession stands on.

1.3 Independence and objectivity

An audit opinion is only worth what the auditor's independence is worth. If the opinion can be bought, pressured, or quietly shaped by self-interest, it is worthless, and everyone who relies on it is misled.

Independence is the *fact* of being free from relationships and interests that could compromise the opinion. **Objectivity** is the *state of mind*: the discipline to judge evidence on its merits, without bias, even when the answer is inconvenient. Independence is something an outsider can check; objectivity needs active safeguards and review throughout the engagement.

The profession catalogues the threats so you can spot them.

> ⚠ Watch out: threats to independence that look reasonable
>
> The dangerous threats are the ones that feel like normal business. A friendship with the CTO. A consulting contract that pays well and renews if the audit goes smoothly. A prior role inside the organisation. A desire to land next year's engagement. None of these is a crime. Each of them is a pressure on the opinion, and each requires a safeguard, or a refusal of the engagement, before you begin.

The safeguards are familiar: rotate the engagement team, separate the audit from any consulting work, document the threats you identified and how you addressed them, and walk away when the threat cannot be reduced to an acceptable level. The discipline is not to pretend you have no interests. It is to be honest about them and act accordingly.

1.4 The ISACA Code of Ethics

Information security auditors work within a professional code. ISACA's Code of Ethics is short and worth knowing by heart, because it is the standard your professional conduct will be measured against. Its obligations come down to a few commitments: support the organisation's legitimate objectives while maintaining your independence; act with due care and competence; keep information confidential and protect privacy; and uphold the reputation of the profession.

Read it once and it sounds like generic good behaviour. Read it on the day a client asks you to soften a finding so a deal closes, and you find out what it actually costs. The code is not a poster. It is the answer you are expected to give when the pressure arrives, and the reason "no" is sometimes the only professional response.

1.5 Why would anyone invite an audit?

Step back to the question Tessera's CTO has not fully asked: *why pay someone to come and find your problems?*

The honest answer is that an organisation invites an audit because the opinion is worth more than the cost to someone. For Tessera, certification unlocks enterprise customers whose procurement teams will not sign without it. For a board, an independent opinion is protection against the day something goes wrong: evidence that oversight was exercised, not neglected. For regulators, it is compliance made visible. And, less flatteringly but just as truly, organisations invite audits because the people inside them already suspect the gaps and want a credible outsider to name them.

The auditor's job is to be worth that trust: to deliver an opinion that is genuinely independent, even when the organisation that paid for it hopes for a different answer. Tessera is paying you to find out whether they are ready.

1.6 Three kinds of control

Before the engagement goes further you need the vocabulary every audit uses. Controls (the safeguards an organisation puts in place to manage risk) come in three kinds, and knowing which kind you are looking at tells you what evidence will prove it works.

Preventive controls stop something going wrong. An access-review process that removes leavers' accounts before they can be misused. A firewall rule. Mandatory training before a user gets privileges.

Detective controls notice that something has gone wrong, after the fact. A log that records a failed login. An alert when an admin account is created out of hours. A reconciliation that finds a discrepancy.

Corrective controls fix something once it is found. An incident-response plan. A backup you restore from. A patch you push out.

Most real defences are a chain of all three, because no single control is reliable on its own. A preventive control fails silently; you only find out it failed because a detective control caught it; you only recover because a corrective control exists. When you audit, you are testing the whole chain, and you are always asking the question that separates a control that *exists* from one that *works*.

Tessera Case: Where Tessera's hats show

From the outset of the engagement you wear all three hats at once. As **counsellor**, you explain the management-system requirements and how necessary controls are selected and justified. Annex A's 93 controls are a reference set, not an undifferentiated mandatory checklist. As **partner**, you agree how the engagement will run and what access you will get (limited, for now). As **investigator**, you file away the CTO's opening claim ("we're basically ready") as the first assertion the evidence will later confirm or refute. Every chapter from here tests that claim a different way.

AI Field Note: Exploring the control categories

An illustrative draft labels a scheduled access review "preventive because it stops former staff logging in." The label depends on the mechanism. A periodic review detects inappropriate access; subsequent removal corrects it. An automatic disable at termination prevents later use of that credential. Write the mechanism and the evidence you would inspect before choosing a category. A model's label, correct or otherwise, does not perform that analysis for you.

Auditing AI: Can an AI be independent?

Independence is a fact and objectivity is a state of mind, and an AI has neither. It has no relationships to disclose, true, but it also has no stake, no accountability, and no capacity to *refuse* an engagement when a threat cannot be managed. More subtly, an AI trained on an organisation's own data, or embedded in the tooling an organisation pays for, has interests of a new kind: commercial, algorithmic, and invisible.
So can an AI deliver an audit opinion? It can *produce* one. It cannot *stand behind* one, which is the entire point of an opinion. As AI-assisted controls and AI-generated evidence spread through the estates you audit, the question stops being theoretical. We return to it in Chapter 7, when we ask whether you can trust a log an AI produced.

Evidence Locker: lock this in (Engagement milestone 1)

Open your Evidence Locker with the engagement's foundation. Record: the **mandate** (who engaged you, against what criteria, to deliver what opinion); the **independence threats** you identified for this engagement and the **safeguards** applied; and your one-line restatement of Tessera's opening claim, the assertion the rest of the engagement will substantiate or refute. This is not note-taking. It is the first entry in a defensible audit

trail.

1.7 From mandate to evidence

E01 in the fixed pack defines this as a readiness assessment. An internal audit evaluates the organisation's own management system; a readiness assessment prepares for an external process; a certification body conducts its own audit and makes its own certification decision. Their roles and independence requirements cannot be treated as interchangeable.

Here is a first working paper. **Criterion:** P-IT requires full access revocation within 24 hours. **Evidence requested:** a dated termination record, all credential ownership records and disable events. **Test:** reconcile identities and recompute elapsed time. **Possible conclusions:** met for the tested record, exception, or insufficient evidence. A signed policy alone establishes none of those operating results.

1.8 Practice: accept the mandate?

Time: 15 minutes. No AI required. Read E01. Write a 150-word acceptance note naming the engagement type, subject, criteria, reporting limit and the analyst's self-review threat. State a safeguard and the condition under which you would decline. Add it to milestone 1.

Check: your authority must stop short of certification and unauthorised production testing. A team change must prevent the analyst assessing their own integration; simply declaring the relationship is insufficient. Answer checks give the common standard for the locker.

The next chapter develops the risk priorities behind the programme.

Chapter 2

Risk? Foundations of Risk Management

What could go wrong, and how do we measure it?

Tessera Case: "We've covered the big risks"

Day three of the engagement, an email lands from Tessera's CTO. Attached is a polished spreadsheet: the draft risk register, thirty-odd rows, colour-coded green and amber, not a red cell in sight. "We've covered the big risks," she writes. "Let me know if you need anything else for the risk assessment." That attachment is your first real artefact of the engagement, and the claim stapled to it is, as always, the thing to test. A register that rates everything medium is not evidence of low risk. It prompts questions about the method, assumptions and evidence. The ratings may be reasonable; their uniform colour does not decide that.

2.1 What risk actually is

Risk is the effect of uncertainty on objectives. That is the ISO definition, stripped to its bones, and it is better than it sounds. Two words do the work. **Uncertainty** means you do not know whether something will happen, only that it might. **Objectives** means risk is always measured against something an organisation cares about:

revenue, reputation, customer trust, compliance, availability. A threat that cannot touch any objective is not a risk worth managing. A threat that can is, no matter how unlikely it feels on a calm day.

Notice what risk is *not*. It is not a threat, and it is not a vulnerability, though both create it. A threat is an actor or event that could cause harm: a ransomware crew, a flood, a careless insider. A vulnerability is a weakness that a threat could exploit: an unpatched server, a shared admin password, an offboarding step that never runs. Risk is what you get when a threat meets a vulnerability and the result could damage an objective. Tessera's unpatched server is not a risk by itself. The ransomware crew that could reach it, and the revenue loss and certification delay that would follow, is the risk.

This three-part model, threat plus vulnerability plus impact on an objective, underlies every risk register. Most of the optimism you will spend this chapter correcting comes from someone quietly dropping one of the three: naming a threat with no vulnerability, a vulnerability with no credible threat, or an impact with no objective attached.

2.2 The risk lifecycle

Risk management is not a document you produce once. It is a cycle you run, repeatedly, for as long as the organisation exists. ISO/IEC 27005 lays the loop out, and NIST SP 800-30 walks the same path in slightly different language. The shape is the same.

You **establish context**: what is in scope, which objectives matter, what appetite for risk the organisation has set. You **identify** risks: the threats, the vulnerabilities, the scenarios where the two meet. You **analyse** each one, estimating likelihood and impact. You **evaluate** them, ranking the analysed risks against your criteria to decide which deserve treatment. You **treat** them, choosing from the four options we will come to. And you **monitor and review**, because risks change, controls drift, and a register that was right in January is stale by July.

The cycle matters more than the artefact. A risk register is a snap-

shot of one trip around the loop. The organisation that updates it annually, to satisfy an auditor, has a document. The organisation that runs the loop continuously has risk management. When you audit, part of what you are testing is which of those Tessera is.

2.3 Likelihood × impact

Many risk methods consider likelihood and impact. This book uses a simple ordinal matrix; multiplication of category scores is a planning convention, not a universal risk formula. How likely is this to happen, and how bad would it be if it did? Score each on a scale, combine them, and you have a rating you can rank, plot on a matrix, and defend.

Likelihood is usually a blend of two things the register rarely separates: how often the threat *tries*, and how likely it is to *succeed* given the controls in place. A phishing campaign hits Tessera's staff hundreds of times a week; that is high threat activity. Whether it becomes an incident depends on whether the training, the mail filter, and the MFA hold. Conflating the two is how registers end up with every externally-facing risk marked "high likelihood." It is also how they end up low: rating the attempt frequency and then quietly assuming the controls work, without ever testing them.

Impact is where the optimism lives. Organisations under-rate impact because they measure the obvious cost and miss the cascading one. A lost laptop is a replacement cost. A lost laptop holding an unencrypted customer list may require breach assessment, notification if the legal conditions are met, and contractual response. The first number is small. The second is the one that ends careers. Your job, when you read an impact rating, is to ask which of those two numbers the author actually wrote down.

The matrix is seductive because it produces a tidy colour. Green, amber, red. Treat the colour as a hypothesis, not a conclusion. Two risks sitting in the same amber cell can be wildly different in what they demand of you, because the matrix has flattened a judgement into a square. We will come back to why, in the Watch out at the

end.

2.4 The risk register and the risk owner

The risk register is where the lifecycle leaves a paper trail. Every identified risk gets a row: a description, the assets and objectives it threatens, a likelihood and impact rating, the treatment chosen, the controls that implement the treatment, and a residual rating once those controls are in place. Done well, it is the most honest document in the organisation. Done poorly, it is theatre.

There is one column that gets neglected more than any other, and it is the one that determines whether the register functions: **the risk owner**. Every risk needs a named individual, not a team, not "the business," accountable for keeping it managed. Ownership is not the same as blame. It is the answer to the question "who will notice when this risk changes, and who will act?" A risk without an owner is an orphan. It will drift until it becomes an incident, and then someone will discover that nobody owned it, which is exactly when ownership would have mattered.

ISO/IEC 27001:2022 makes this explicit in its organisational controls: roles and responsibilities for information security must be defined and assigned. The risk owner is the sharpest test of whether that control is real. When you audit Tessera's register, look at the owner column first. If it names only teams, ask how responsibility resolves to an accountable role or individual. Record a finding only after testing the applicable requirement and the actual assignment.

Tessera Case: The preliminary Tessera risk matrix

Here is the register as it arrives, trimmed to the rows that matter. Looks complete. Looks disciplined. Read it as the auditor, not the recipient.

Risk	Likelihood	Impact	Rating	Owner
Tenant data leakage between customers in multi-tenant platform	Low	Medium	**Medium**	Engineering
Ransomware via phishing of staff	Medium	Medium	**Medium**	IT
Insider misuse of production DB access	Low	Medium	**Medium**	Management
AWS region outage, platform unavailable	Low	High	**Medium**	Engineering
Loss of certification due to failed audit	Low	High	**Medium**	CTO

Treat these as management's initial labels, with their rationale still to be obtained. They do not consistently follow E02's subsequently agreed scoring method: "low × medium" would score two, not medium. Record that methodological mismatch and ask which method the preparer used. Do not silently recompute management's labels as though their assumptions were known.

For a worked revision, use region interruption. Before testing recovery, assign likelihood 2 (plausible) and impact 3 (severe against service obligations): score 6, high for planning. The likelihood is an explicit assumption, not a frequency estimate. E08 later supplies recovery evidence that may affect the assessment. A low residual rating cannot be justified solely by the existence of the recovery policy.

2.5 Treatment: avoid, mitigate, transfer, accept

Once a risk is evaluated, you treat it. The vocabulary is small and worth memorising, because every control you audit for the rest of this book is implementing one of these four decisions.

- **Avoid.** Eliminate the risk by removing the source. Decommission the system, switch off the feature, exit the market. Decisive, often expensive, sometimes the only honest answer.
- **Mitigate.** Reduce likelihood or impact by putting controls in place. Most of information security is mitigation: patching, MFA, encryption, access reviews, logging, training. Mitigation rarely removes a risk; it lowers it to a level the organisation can live with.
- **Transfer.** Move the risk, or its cost, to another party. Cyber-insurance is the obvious example. A managed-service contract that carries an SLA is another. Transfer is never total: insurance covers the money, not the reputational damage, and a contract does not return your customers' data. You have transferred the financial consequence, not the underlying exposure.
- **Accept.** Acknowledge the risk and choose to live with it, explicitly, with a reason, signed by someone with the authority to accept it. Acceptance is legitimate. *Implicit* acceptance, where a risk is simply never treated and never owned, is the most common failure mode in the registers you will read.

The choice is rarely pure. A real treatment plan combines them: mitigate hard, transfer what remains through insurance, and accept

the residual, with the owner's name on the acceptance. The discipline is to make the choice deliberately and record it. A control with no treatment rationale attached is a control someone installed on instinct and never justified.

2.6 Residual risk

Inherent risk is the risk before controls: the raw exposure, threat meeting vulnerability with nothing in the way. **Residual risk** is what remains *after* treatment. Mitigation moves a risk from its inherent level down to a residual level the organisation has decided is acceptable.

Residual risk is where auditors live. Inherent risk tells you about the world. Residual risk tells you whether the controls are doing their job. A risk that sits at "High inherent, High residual" may remain high despite functioning controls, or may reflect weak or unverified treatment. Distinguish those explanations. A risk at "High inherent, Low residual" has controls you now need to test, because the entire justification for that comfortable residual rating rests on them. Every residual rating in a register is a claim about a control. Your job, for the rest of the engagement, is to substantiate those claims one by one.

⚠ Watch out: residual is not eliminated, and one rating can hide a swarm

Two traps, both common, both dangerous.
First, treating *residual* as if it meant *eliminated*. It does not. Residual risk is the risk that remains after treatment, and it remains because no control is perfect, because controls fail, and because the threat landscape moves. A register full of "residual: low" is not a register of solved problems. It is a register of bets on controls, and bets can lose. If the organisation talks as though treatment closed the risk, the treatment is probably aspirational.
Second, the single-point likelihood × impact rating hiding

> aggregation and velocity. One phishing email rated "medium" tells you almost nothing, because phishing is not a one-off. It is a continuous stream. The relevant question is the likelihood that *at least one* succeeds over a year, not the likelihood of any single attempt. Likewise, a risk whose impact compounds fast (a tenant-data leak that spreads as customers discover it, a ransomware payload that moves laterally in minutes) cannot be captured by a static impact score. A matrix cell is a still photograph. Real risk has a frame rate. When you re-rate, ask not just "how likely, how bad" but "how often, and how fast does it get worse."

2.7 Two standards, one loop: ISO/IEC 27005 and NIST SP 800-30

You will meet two risk standards repeatedly, and it helps to know how they differ and why it rarely matters which one you reach for.

ISO/IEC 27005 is the information security risk management standard that sits beside ISO/IEC 27001. If 27001 tells you to *do* risk management (it is mandatory: Clause 6.1.2 requires a risk assessment and Clause 6.1.3 requires a risk treatment plan, and the Statement of Applicability is built directly from the treatment decisions), then 27005 tells you *how*, in process terms: context, assessment, treatment, acceptance, communication, monitoring. It is the method document for the ISMS. For Tessera, chasing 27001 certification, 27005 is the natural home for the methodology their register should follow.

NIST SP 800-30 is the US federal equivalent, "Guide for Conducting Risk Assessments." It is more granular on the assessment step itself: it breaks the analysis into identifying threat sources and events, vulnerabilities, and predisposing conditions, then determining likelihood, then impact, then risk. It is the document to reach for when you want a rigorous, repeatable walk through a single assessment.

Their scopes differ: ISO/IEC 27005 addresses information-security

risk management, while NIST SP 800-30 Rev. 1 concentrates on risk assessment. Neither makes the other's full process mandatory merely by being mentioned. An auditor who can read a Tessera register and map its columns to either standard, fluently, has the skill; the partisan who insists one is correct and the other is not has missed the point. The risk-based audit approach does not care which standard produced the register. It cares whether the register survives scrutiny.

2.8 The risk-based audit approach

The **risk-based audit approach** uses risk to decide where the audit looks hardest. You do not test every control with equal effort, because no engagement has the time or the budget for that, and because uniform effort is wasted effort: it spends the same care on a low-impact nicety as on a load-bearing control that protects the crown jewels.

Use the register as an input, then challenge it. Consider inherent exposure, dependence on critical controls, prior results and evidence reliability. A high-inherent/low-residual risk may need substantial operating tests because the low rating depends on those controls. Allocate depth proportionately while preserving required coverage; a management rating does not justify an existence-only test.

There is a second, subtler dimension. You are not only using risk to plan the audit; you are auditing risk management itself. Is the register complete? Are the owners real? Do the ratings survive a challenge? Is the cycle actually running, or was it last touched the week before you arrived? For an organisation certifying to ISO/IEC 27001, a sound risk management process is not optional; it is the spine of the whole management system. An opinion on Tessera's readiness is, in large part, an opinion on whether their risk management is real. You cannot certify an organisation that manages controls but not risk.

The frameworks in the next chapter give a structured way to treat the risks identified here. The audit plan in Chapter 4 is built on the

risk-based priorities you set here.

> ℹ AI Field Note: Drafting the matrix, then fixing it
>
> Consider this illustrative draft: “Tenant leakage: medium; encryption limits harm to one customer.” The supplied record establishes neither the affected population nor that encryption prevents authorised application access. Ask for the data flow, isolation boundary and contractual criteria. Retain uncertainty until those facts are available.
> A second draft might declare every leak legally notifiable. That also overreaches. Notification depends on the applicable scheme and facts; chapter 9 separates assessment from notification. Your correction should remove the unsupported claim, not automatically replace medium with high.

> ! Auditing AI: Rating the risk of the model itself
>
> The likelihood × impact framework was built for threats that steal data or break systems. It applies, with a twist, to AI systems themselves, because an AI deployment is a new source of risk that an organisation can own, treat, and rate like any other.
> Treat the model as an asset with its own threats and vulnerabilities. A threat source might be a prompt-injection attack, a training-data extraction attempt, or simply drift as the model is retrained. The vulnerabilities are familiar to anyone who has worked with these systems: they confabulate, they leak training data under the right queries, and they fail in ways that look confident rather than loud. The impact? A Tessera support chatbot that hallucinates a refund policy it just invented is a customer-trust risk. An AI assistant that summarises customer tickets and leaks one tenant’s details into another tenant’s summary is the cross-tenant leak from the Field Note, delivered through a new channel.
> When you audit an organisation that has deployed AI, the

risk register should contain rows for the model: who owns it, how it was assessed before deployment, what monitoring catches drift or misuse, what the residual risk is. If those rows are missing, the organisation has not managed the risk; it has assumed it. That is the very failure this chapter is about, wearing a new face.

 Evidence Locker: lock this in (Engagement milestone 2)

Lock in your **re-rated Tessera risk matrix**. For every rating you changed, document the rationale in a sentence another auditor could follow: *what context the original rating missed* (contractual, regulatory, operational, or aggregation), *what you re-rated it to*, and *on what evidence*. Note the **owner** you would assign where the register has none, and flag any risk you believe is **missing entirely**. By the end, your matrix should read less like the CTO's "we've covered the big risks" and more like a defensible argument about what could actually go wrong at Tessera. This is the artefact the rest of the engagement will keep returning to.

2.9 Practice: defend a rating

Time: 20 minutes. No AI required. Use E02 and E08. Rebuild the region-outage row with a named owner, inherent likelihood/impact assumptions, the proposed recovery treatment, and the evidence needed before accepting a residual rating. Then choose a second row from the opening register and mark unknown facts explicitly. Add both to milestone 2.

Check: separate management's original label from your agreed scoring method. A high score needs a rationale; a low residual score needs support for the controls it depends on. An evidence gap is not a measured incident probability. Do not require your revised matrix to contain a particular colour.

Framework selection next turns those priorities into criteria.

Chapter 3

Which? Frameworks and Standards

Which yardstick do you measure Tessera against, and why not all of them?

Tessera Case: "Why can't we certify against everything?"

The board meeting runs long. Tessera's CTO has the slide up: ISO/IEC 27001, NIST CSF, the ASD Essential Eight, SOC 2, PCI DSS, a privacy overlay. "We're a SaaS company serving enterprise and government customers," she says. "Surely more badges is more trustworthy. Why not certify against all of them?" It is a reasonable question from a reasonable person, and it is exactly the wrong instinct. Your answer separates the requested certification from other binding obligations and optional cross-checks. The whole meeting turns on why that distinction matters, and it sets the criteria every later chapter in this engagement will be measured against.

3.1 Frameworks are tools, not trophies

Before you choose, get clear on what these things actually are. A framework is a structured set of expectations: what good looks like, organised so an organisation can find its gaps and an auditor can

test against them. They differ in scope, in origin, and in what you can *do* with the result.

Some frameworks are **certifiable**. ISO/IEC 27001 is the canonical example: an accredited body audits you against it and issues a certificate the market recognises. Certifiable frameworks are scarce and valuable precisely because the opinion behind them is independent and repeatable. An accredited certification body can issue accredited certification within its scope. Other assurance engagements have different mandates and reporting rules.

Others are **assessment or maturity frameworks**. NIST CSF and the ASD Essential Eight live here. You can score yourself against them, an assessor can rate your maturity, and the result is genuinely useful. These are not ISO-style certification schemes. An assessment against their outcomes can still be evidence-based; its report should state scope, method and limitations.

This distinction is the source of the board's confusion, and it is worth naming out loud in the room. "More badges" only counts if the badges are the kind procurement teams and regulators actually ask for. For Tessera, chasing ISO/IEC 27001 is not a stylistic choice; it is the answer to a specific business question, and the other frameworks answer different questions. Your job in that meeting is to choose the framework that answers the question you are actually being asked, then explain why the rest come along for a different reason.

3.2 ISO/IEC 27001:2022: the certifiable yardstick

ISO/IEC 27001 is the standard Tessera will be certified against, and it earns that role for a specific reason: it is the internationally recognised, certifiable ISMS standard. An ISMS, an information security management system, is not a checklist. It is a *management system*: a set of policies, processes, risk decisions, and controls that an organisation runs continuously and that an auditor judges as a living thing. The standard's clauses 4 through 10 lay out how that system is built: understand your context, set leadership accountability, plan

around risk, support it with resources and competence, operate it, evaluate its performance, and improve it. Plan, do, check, act, repeated forever. When you audit 27001, you are auditing whether that loop actually turns, not whether a binder of policies exists.

The 2022 edition restructured Annex A, the controls catalogue, decisively. The 2013 edition scattered 114 controls across 14 domains that were easy to read but hard to reason about. The 2022 edition collapses them to **93 controls** organised into **four themes**, and the themes are almost self-explanatory:

- **A.5 Organizational controls** (37): the governance, policy, supplier, and risk-management controls. The "what we have decided" theme.
- **A.6 People controls** (8): the employment-lifecycle controls, screening, terms, training, disciplinary process.
- **A.7 Physical controls** (14): the offices, the server room, the clear-desk rules, the physical entry logs.
- **A.8 Technological controls** (34): access control, cryptography, logging, secure development, the things most people picture when they hear "security."

If you are going to hold one framework in your head as the yardstick, hold this structure. The themes map onto the way a real organisation divides its work: people who decide, people who are employed, places that are secured, and technology that is configured. When you test a control, you immediately know which part of the business it touches and whose evidence you will need.

One pairing worth remembering: 27001 is the certifiable standard, and its companion **ISO/IEC 27002** gives implementation guidance for each control. You audit against 27001; you reach for 27002 when you need to understand what a control is actually asking for. They are a pair, and confusing them is a common rookie mistake. The certificate says 27001. The "how do I do this well?" book is 27002.

3.3 NIST CSF 2.0: the functions lens

The NIST Cybersecurity Framework takes a different cut through the same problem. Where ISO 27001 organises by *who does it*, CSF organises by *what you are trying to achieve*, expressed as six functions:

Govern, Identify, Protect, Detect, Respond, Recover.

The newest of these, **Govern**, is the headline change in CSF 2.0 (released in 2024), and it is the one that matters most to an auditor. CSF 1.1 already included governance under Identify. Version 2.0 elevates it to its own function, as NIST's change summary (https://www.nist.gov/cyberframework/faqs) explains. Governance is where accountability, risk appetite, policy, and oversight live, and pulling it out of the wings and onto the stage is the single most consequential revision in the update.

CSF is not certifiable, and that is a feature rather than a limitation. It is a *communication and orientation* framework. You use it to explain posture to a board, to map what you have, to spot whether your coverage is lopsided (heavy on Protect, thin on Detect, say). For an auditor it is an excellent cross-check because it asks a question ISO 27001's themes do not: *do you cover the full lifecycle, from understanding what you have through to recovering when it breaks?*

One warning that catches people out: CSF is not a control catalogue. It is functions, then categories, then subcategories that *reference* other standards. It points at controls rather than containing them. Its outcomes need translation into criteria and evidence requests appropriate to the engagement. Evidence can support a CSF assessment as well as an ISO assessment; neither framework supplies proof by itself.

3.4 The ASD Essential Eight: the baseline

The Essential Eight is the most specifically Australian artefact in the set, and for a Perth company chasing government work, that specificity is its value. Published by the Australian Signals Directorate,

it is a **baseline**: eight mitigation strategies the ASD judges most effective at stopping common attacks.

The eight are deliberately concrete and unglamorous: application control, patching applications, configuring Microsoft Office macros, user application hardening, restricting administrative privileges, patching operating systems, multi-factor authentication, and regular backups. Each is scored across **maturity levels 0 to 3**, whose requirements address increasing adversary capability and techniques. They are not generic labels for documentation or management maturity; consult the ASD maturity model (https://www.cyber.gov.au/business-government/asds-cyber-security-frameworks/essential-eight/essential-eight-maturity-model) for the strategy-specific requirements. A government customer asking for your Essential Eight maturity is not asking for a certificate; they are asking a pointed question about how well you do the unglamorous basics.

Two things to keep straight. First, the Essential Eight is a *baseline*, not a complete framework. It will tell you whether your patching and admin-privilege hygiene is sound; it will not tell you whether your supplier risk management is adequate or your incident-response plan works. Treat it as the floor, not the ceiling. Second, it was designed around Microsoft-centric estates, which fits most organisations but not all. For Tessera, built on AWS with a mix of tooling, some strategies map cleanly and some need interpretation. That interpretation is exactly the kind of judgement the standard cannot supply and the auditor must.

A strong Essential Eight result does not establish immunity from compromise. Its coverage is bounded; supplier governance, service architecture and additional obligations need their own assessment.

3.5 Pick one yardstick, cross-check the rest

Use a principal standard to organise this engagement, while recording every other binding criterion. Tessera wants ISO/IEC 27001 certification, so that is the principal standard. CSF and the Essential

Eight are supplementary lenses unless a contract or other obligation makes particular outcomes mandatory. A payment obligation or privacy duty cannot be dismissed because it sits outside the preferred framework.

Multiple assurance programmes may be justified by different customers. **SOC 2** is an attestation report on controls relevant to selected Trust Services Criteria, not an ISO certificate. A Type II report addresses a period; a report's scope, exceptions and user responsibilities matter to reliance. AICPA's SOC 2 overview (https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2) describes its purpose.

3.6 Applicability before the test plan

The **Statement of Applicability (SoA)** records necessary controls, why they are included, implementation status and justified Annex A exclusions. Risk treatment can require controls beyond Annex A. The management-system requirements remain part of the audit; "not applicable" is not a way to remove an inconvenient requirement.

Read E03's teaching extract. "Implemented" with no evidence reference is a management claim to test. A.5.18 concerns access rights; A.6.5 concerns responsibilities continuing after employment. A numbered control reference alone does not establish a precise operational deadline. Here the two-hour and 24-hour criteria come from the fictional policies.

This edition uses ISO/IEC 27001:2022 with Amd 1:2024 (https://www.iso.org/standard/88435.html), the climate-action amendment. Record consideration of climate-related relevance to organisational context and interested-party requirements; do not silently omit the amendment. Use authorised copies for exact normative wording. The source guide identifies editions and the limits of these teaching paraphrases.

3.7 Supplier assurance before exclusions

E09's fictional SOC 2 summary covers a payment API through December 2025. It has an exception and complementary user controls, with no supplied 2026 bridge evidence. Read the subject, service, period, report type, exceptions and customer responsibilities before deciding what reliance is justified.

Do not exclude supplier oversight merely because a processor performs the transactions. You may lack authority to test the provider directly, yet still need to test Tessera's selection, contracts, monitoring and complementary controls. An unavailable report or missing period belongs in the evidence-gap register. Chapter 4 carries that limitation into scope and procedures.

3.8 Mapping and reconciling

Once you have a yardstick, you map. The point of a cross-mapping is not to prove the frameworks are equivalent; they are not. It is to confirm you have no blind spots, and to translate evidence so a control tested once can satisfy multiple audiences. A government customer wants to see Essential Eight maturity; a board wants CSF posture; your certification auditor wants 27001 evidence. One well-built mapping lets all three read the same controls in their own language.

The mapping is **many-to-many**, and saying so plainly saves you from the most common mapping error. One ISO 27001 control, access reviews, touches Protect and Detect in CSF and several Essential Eight strategies (admin privileges, MFA, application control). One Essential Eight strategy, patching, maps to a technological control *and* to organizational policy. A neat one-to-one table is a lie. An honest many-to-many table is a working paper you can defend.

Apply the same scepticism to the frameworks themselves: a mapping is an *assertion* about correspondence, and assertions get tested. When someone hands you a cross-mapping, your job is to spot the row that claims two controls are equivalent when they are merely

adjacent. "Both talk about logging" is not "both require the same evidence." Frameworks overlap; they do not coincide. The discipline of mapping is the discipline of saying exactly how much two controls actually share, and no more.

Tessera Case: Choosing the yardstick, and the starter map

You take the board through the decision on one slide. **Yardstick:** ISO/IEC 27001:2022, because certification is the business goal and 27001 is the certifiable answer. **Cross-check 1:** NIST CSF 2.0, to confirm the controls span Govern through Recover. **Cross-check 2:** the ASD Essential Eight, because government customers expect the baseline and Tessera wants the work. The board signs off, not because more is better but because each framework now has a defined job.

You start the cross-mapping as a working paper, not a deliverable, and you keep it honestly many-to-many. A representative category-level slice, not a claim of full outcome equivalence. PR.PS is Platform Security; PR.IR is Technology Infrastructure Resilience. Verify subcategories and required evidence in the CSF 2.0 Core (https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf):

ISO/IEC 27001:2022 (yardstick)	NIST CSF 2.0 (cross-check)	ASD Essential Eight (cross-check)
A.5.15 Access control	PR.AA (Identity, authentication, authorization)	Restrict administrative privileges; MFA
A.8.7 Protection against malware	PR.PS; DE.CM	Application control; user application hardening
A.8.13 Information backup	PR.DS; RC.RP (recovery use)	Regular backups
A.8.19 Installation of software on operational systems	PR.PS (Platform Security)	Application control (partial overlap)

ISO/IEC 27001:2022 (yardstick)	NIST CSF 2.0 (cross-check)	ASD Essential Eight (cross-check)
A.5.7 Threat intelligence	ID.RA; DE.AE	*(no Essential Eight equivalent; the baseline does not cover it)*

The last row is the one to notice. Threat intelligence is a real 2022 control with no Essential Eight home, and a mapping that pretends otherwise is precisely the lie this table refuses to tell. Cross-checks expose gaps as honestly as they expose coverage, and a gap you have named is a gap you can manage.

i □ AI Field Note: Mapping controls across frameworks

An illustrative draft maps "A.8.19 □ PR.IR (Platform Security) □ patching" as an exact equivalence. Check it in stages. Platform Security is PR.PS. Software-installation restrictions and patch management overlap, but are not the same requirement. An installation allow-list test does not establish timely patching. Correct the category, state partial overlap and specify each separate test.
Do not upload a licensed standard to a model without permission. Public control titles and original teaching criteria are enough for this exercise.

! □ Auditing AI: Which controls does an AI deployment fall under?

The frameworks were written before generative AI sat inside the estate, so no control is labelled "AI." That does not mean AI is uncovered. Treat an AI deployment as what it is: a cloud-delivered, data-hungry, rapidly-changing software system, and the 2022 controls land on it hard.
Relevant 2022 controls include both newly introduced con-

trols and controls carried forward or reorganised from the prior edition. **A.5.23 Information security for use of cloud services** applies directly, since most enterprise AI is consumed through a cloud API and Tessera's data leaves its boundary to reach the model. **A.5.7 Threat intelligence** matters more, not less: model-abuse techniques, prompt-injection trends, and data exfiltration via tool calls are exactly the threat intel a current ISMS needs. **A.8.11 Data masking** applies to the training and prompt data that may carry personal information. **A.8.25 Secure development life cycle** (and its partner A.8.28 Secure coding) applies to the pipelines that build, fine-tune, and deploy models. And **A.5.30 ICT readiness for business continuity** applies the moment a business process depends on an AI service that can degrade silently.

The audit move is to take each AI system in scope, walk it through these controls, and ask the standard question: *what evidence proves this control is present and working for this system?* An AI deployment does not earn an exception. It earns a closer look.

 Evidence Locker: lock this in (Engagement milestone 3)

Time: 25 minutes. No AI required. Build a criteria sheet from E01, E03 and E09. Record the principal standard, the two policy deadlines, the supplier-report scope and missing period, and three necessary control areas from the SoA extract. For each, name evidence you would need. Classify the two-hour/24-hour conflict as unresolved, not an invitation to choose the easier test.

3.9 The question, answered

Framework choice establishes what the engagement will assess. Applicability and a criteria register make that choice testable. Keep contractual and legal obligations visible even when a single standard organises the report. Next, turn the criteria into a bounded

programme.

3.10 Take it to the AI

This optional exercise follows the paper task. Use only E03's original teaching criteria and the illustrative mapping above.

> **Role:** Review a trainee's criteria mapping.
>
> **Task:** Identify unsupported equivalence claims. Do not invent standard wording or unseen evidence.
>
> **Context:** The proposed mapping treats installation restrictions as proof of timely patching. Platform Security is PR.PS; PR.IR is Technology Infrastructure Resilience. The book's case has not supplied a patch test.
>
> **Format:** For each claim, give the supporting supplied fact, the missing test and a bounded correction.

Check the answer against the source and your criteria sheet. Keep a correct answer if supported; disagreement is not a required performance.

Chapter 4

Scope? Audit Planning and Methodology

An audit that tries to verify everything verifies nothing.

Tessera Case: "Just a quick health check"

Tessera's CTO opens the second conversation with a request that sounds modest. "Before we go deep, can you just do a quick health check? A general sense of where we stand." Reasonable, and dangerous. A "quick health check" has no boundary, no criteria, and no definition of done. It is the kind of engagement that swells until it is neither quick nor a check, and that ends with an opinion so vague no one can rely on it. Your job here is to resist the open-ended ask and replace it with something defensible: an engagement with a stated objective, a drawn boundary, and a moment when you can say, on the evidence, that the work is finished.

4.1 Scope before substance

You cannot audit everything, and you should not try. An information security management system touches every server, every account, every supplier, every line of policy, and every corridor with a lock on it. A certification-readiness audit has weeks, not years, and limited access. The gap between what exists and what you can examine is

enormous, and the auditor's first job is to close it intelligently rather than pretend it is not there.

Separate three decisions. **Scope** bounds the subject and period. **Coverage** records which applicable requirements will be assessed. **Test depth** determines the procedures and evidence needed for each. A broad scope can still have clear priorities. A short deadline does not permit silently omitting a required control.

A vague "all security controls" brief needs clarification before acceptance. Establish the service boundary, dependencies, evidence access and reporting limits. Revisit those decisions when new information appears, recording the reason and agreement.

4.2 The four things you must fix before you start

Before you review a single document or book a single interview, you must fix four things in writing. They are the legs the engagement stands on, and a wobble in any one of them propagates through everything that follows.

The **audit objective** is the question the engagement exists to answer. For Tessera, that question is specific: *is Tessera's information security management system ready for ISO/IEC 27001:2022 certification?* Not "is Tessera secure," which is unanswerable, and not "what is wrong with Tessera," which has no end. A good objective is a question with a finite, opinion-shaped answer.

The **criteria** are the benchmark the subject matter is measured against. You cannot say whether something conforms without first saying what it should conform to. Tessera's criteria include ISO/IEC 27001:2022 with Amd 1:2024, the necessary controls in its SoA, applicable obligations and its own policies. E01 and E03 record the teaching criteria. The criteria decide what counts as evidence and what counts as a finding.

The **scope** is the boundary: which parts of the subject matter the objective applies to. Which systems, which locations, which busi-

ness units, which period of time, which controls. Scope turns the objective from an idea into a finite piece of work.

And **materiality** is the threshold that decides what matters. Significance guides priorities and the executive summary. Record supported nonconformities against applicable criteria even when they are individually low severity. Materiality is what stops the report from being an exhaustive catalogue of minor nicks and makes it a judgement about the things that affect the opinion.

The objective is the question; the criteria define "good"; the scope draws the fence; significance guides how findings are prioritised and communicated. Fix all four, and the engagement has a spine. Leave any vague, and you are back to the health check.

4.3 Materiality is not completeness

Coverage and significance answer different questions. Coverage asks whether required areas were addressed. Significance asks how a result affects the conclusion and action priorities. They are complementary.

A spelling error that changes no obligation may be an editorial observation. Missing evidence for a required access review is an audit issue even if no misuse was found. Do not import a financial-audit numerical threshold as permission to suppress management-system nonconformities.

Maintain a complete findings register, then write a prioritised executive summary. Where access or time prevents a required test, record the limitation and its effect on the opinion. "We did not assess it" is clearer than an unsupported low-risk conclusion.

4.4 The engagement letter

Scope decisions are only worth something if they are agreed, and agreement that is not written down is an argument waiting to happen. The **engagement letter** is where the four planning primitives,

the objective, the criteria, the scope, the materiality threshold, become binding between you and Tessera. It is part contract, part charter. It says what you will do, what you will not do, what you need from Tessera to do it, and what you will deliver at the end.

A good engagement letter is boring on purpose. It names the parties, the criteria, the objective, and the scope boundary in language a board and a certification body would both recognise. It sets out responsibilities: Tessera provides access and accurate information; you provide competence, independence, and an evidence-based opinion. It records the deliverables, the timeline, and the fees. And it is honest about limits: what the audit will not catch, what "snapshot, not guarantee" means, and how findings will be raised if the picture changes.

The letter is also where the hard conversations happen early. If Tessera wants the acquired subsidiary included, that is a scope and a fee decision, made now, not in week three. If the CTO expects a clean opinion regardless of evidence, the letter is where you restate, in writing, that the opinion follows the evidence and not the deadline. A scope that everyone has read and signed is a scope that survives pressure. One that lives in a hallway conversation does not.

> ⚠ Watch out: scope creep and vanity scope
>
> Scope has two enemies that look like virtues. **Vanity scope** is the impulse to put everything in, because a big scope looks ambitious and "thorough." It is the health check in a suit. **Scope creep** is the slow drift that happens mid-engagement, when a curious finding tempts you to follow it past the boundary, or a stakeholder asks you to "just take a quick look" at something out of scope. Each ask sounds small. Together they turn a finished engagement into one that never ends. The defence is the same for both: every change to scope is a written decision, with a reason, a cost, and a signature. "While we're here" is not a scope.

4.5 The six-stage audit lifecycle

This book groups the engagement into six practical stages. ISO 19011:2026 (https://www.iso.org/standard/19011) provides guidance on management-system auditing; the sequence below is a teaching arrangement, not a quotation of mandatory certification rules. Specific audit programmes may overlap stages and agree different follow-up arrangements.

The six stages, in order:

1. **Initiating.** You establish contact, confirm the engagement is feasible, agree the objective, scope, and criteria, and form the audit team with the competence the engagement needs. The engagement letter is signed here, and the audit programme is begun.
2. **Preparation.** You review the documents Tessera has given you, build the audit plan, and prepare the working papers, checklists, and test procedures that fieldwork will use. This is where the desk audit happens, and where most of an Act I engagement is lived.
3. **Conducting.** The audit itself. The opening meeting, the gathering of evidence through interviews, configuration review, and testing, and the closing meeting where preliminary findings are shared. Evidence is gathered on terms you set, not on terms Tessera chooses.
4. **Reporting.** You prepare the audit report: the findings in a defensible format, the conclusion, and the opinion. The report is drafted, reviewed, and distributed to the agreed recipients.
5. **Completion.** The engagement is formally closed. Working papers are finalised and retained, lessons are captured, and the records that someone may need to reconstruct this audit in three years are put away properly.
6. **Follow-up.** You verify that the corrective actions raised in the report have actually been taken and are working. An audit that reports a finding and never checks the fix is an audit that stops at diagnosis.

The stages are linear, but the decisions inside them are not. Initiation

fixes scope, but preparation often forces a scope correction when the documents reveal something unexpected, and follow-up can reopen an engagement that completion thought was closed. The lifecycle is a spine, not a script. You move through it with your professional scepticism switched on at every stage.

4.6 The audit programme and risk-based scoping

The engagement letter says *what* you will do and *where the boundary is*. The **audit programme** says *how*, in operational detail: which controls you will test, which evidence you will gather for each, which sample sizes, which interviews, and in what order. This book uses "test programme" for the procedure list. Distinguish it from an audit programme covering one or more audits and an audit plan describing the activities and arrangements for a particular audit.

Start with applicable coverage, then choose proportionate depth. The risk register informs this decision, but its residual ratings depend on claims you may still need to test. High inherent exposure with low asserted residual risk can require deep testing of the controls responsible for that reduction.

Write the rationale for each procedure, population and period. If evidence is unavailable, record the gap rather than replacing an operating test with confirmation that a policy exists. Required coverage, evidence reliability and key-control dependence matter alongside risk scores.

4.6.1 A small procedure before the full test

Use E03 and one E04 record. **Objective:** all access disabled within the applicable deadline. **Inputs:** termination time, identity disable time and separately owned key disable time. **Procedure:** match the ID, check that all required credential types are represented, subtract termination from each disable timestamp, and compare the latest disable time with both two and 24 hours. **Output:** met,

exception or insufficient evidence under each policy, with record ID and calculation.

A missing disable event is not automatically proof of active access. Request an independent event source or authorised state check. A current disabled state does not establish when historical revocation occurred.

□ Tessera Case: Drawing the Tessera boundary

E01 fixes the scope: the Perth-managed SaaS ISMS, relevant customer-data flows and supplier dependencies. Direct testing of a supplier's production systems is outside the granted authority. Tessera's supplier governance and complementary controls remain inside the assessment.

E09's payment report ends in December 2025. Its exception and missing current-period evidence mean reliance is unresolved. Record those requests and the effect of their absence. Do not write "covered by SOC 2" as though it were a completed test.

The opening mandate contains no subsidiary in this fixed scenario. If an acquisition were introduced, assess its interfaces and scope implications before deciding whether it can be excluded. A separate legal entity is not automatically outside an ISMS.

i □ AI Field Note: Drafting the audit programme

An illustrative draft says "exclude payment processing because the processor has SOC 2." E09 does not justify that conclusion. Correct the procedure to inspect scope, period, exceptions and complementary user controls, then decide reliance. The missing bridge evidence remains a limitation. No model output can supply a report the case does not contain.

! □ Auditing AI: Scoping the AI surface

The fixed case includes an AI support assistant. An anomaly detector would require a separate work package; later chap-

ters discuss that as a method extension without claiming a completed test. An AI system has a scope of its own: the model, relevant data, prompts and outputs, human review and integrations. State which components and operating period the engagement covers. A model-only test cannot establish the effectiveness of the surrounding control.

The sharper point is that AI changes what "in scope" means over time. A model that behaves one way today can drift after a retrain, so a control that passed in week 2 may not pass in week 8. Scope has to say *when* the AI surface was examined, and the opinion has to honour that snapshot. We will test AI-generated evidence properly in Chapter 7. Here, the lesson is simpler: an AI you cannot see on the security page is still part of the ISMS, and a scope that ignores it is a scope with a hole in it.

 Evidence Locker: lock this in (Engagement milestone 4)

Time: 25 minutes. No AI required. Write a one-page scope and test programme using E01, E03 and E09. Include an access-revocation procedure and a supplier-reliance procedure. For each, state coverage, population/period, evidence required, permitted action and output. Separate an authority boundary from an evidence gap.

4.7 The question, answered

A bounded engagement can support a useful opinion even when evidence is incomplete, provided that the conclusion states the limitations. Next, make the technical objectives precise enough to test.

Chapter 5

Expect? Technical Control Objectives

> *What should be in place, and what does "good" actually look like?*

Tessera Case: The diagram is not the territory

Tessera's head of engineering hands you a single-page architecture diagram early in the engagement. It is beautiful. Boxes for VPCs and subnets, arrows labelled TLS, a padlock on the database, "KMS" stamped on every storage layer, "IAM roles" on every service. He watches you study it, looking for the nod. You give him a different response. You ask, for each box: *what is the objective here, and how would I test whether it is actually met?* The diagram is a claim. Your job, from this chapter on, is to turn each claim into a control objective you can substantiate, or refute, with evidence.

5.1 From control to control objective

Chapter 4's small procedure is a starting point. The **control objective** is the tool that turns a list of controls into an audit.

A control is a safeguard. Encryption is a control. A firewall rule is a control. Multi-factor authentication is a control. A control objective

is the *intent* that control is meant to deliver, written so that intent can be tested. "We encrypt the database" is a control. "Requests through the tested customer-data API require an authorisation decision, with sufficient logging to reconstruct access" is an objective. The first describes a configuration. The second describes an outcome you can try to disprove. That is the difference between auditing a screenshot and auditing a system.

ISO/IEC 27001:2022 gives you the raw material in Annex A.8, the Technological controls, the largest of the standard's four themes. NIST CSF 2.0's Protect function and the ASD Essential Eight give you the same engineering from different angles. None of them hands you the objective. That is your job, and it is the job this chapter teaches: read the control, ask what "good" looks like, phrase it as a statement you could prove or disprove with evidence, and then go look.

Here is a useful test for whether you have written an objective rather than a control. Can you describe how it would *fail silently*? If you cannot, clarify the mechanism and likely failure conditions before choosing a test. The objective is only real once you can picture the version of the world in which the control is present, the dashboard is green, and the objective is still not met. That picture is what you will spend the rest of the engagement trying to find.

5.2 Access control: identity is the new perimeter

For a SaaS company like Tessera there is no perimeter in the old sense. There is no castle with a wall and a moat. There is a set of identities, human and machine, each holding some set of permissions, talking to services that live on someone else's hardware. Get identity right and most of your technical risk falls into line. Get it wrong and nothing else matters, because the attacker walks through the front door with valid credentials.

The first objective is **least privilege**: every identity, human or service, holds only the permissions it needs, and nothing more. That

sounds tidy until you ask for the access review and find the founding engineers still hold administrator rights across production, staging, and every customer tenant, because nobody has ever pruned them. A review may reveal inherited privileges, or may substantiate that they remain justified. Least privilege maps to ISO 27001 A.8.2 (privileged access rights) and A.8.3 (information access restriction), and to the Essential Eight's "restrict administrative privileges" strategy. The objective, though, is the testable version: *any permission not justified by current job function is removed within a defined window.*

The second is **authentication strength**: access requires proof of identity proportionate to the risk, and for anything privileged, that proof resists phishing. Passwords alone fail this objective, and so does a six-digit SMS code relayed to a tired person at midnight. Phishing-resistant MFA, the kind built on FIDO2 and WebAuthn, is what "good" looks like for administrators and for anyone touching customer data. The Essential Eight pushes you here for a reason.

The third is the **identity lifecycle**: accounts are created when someone joins, changed when their role moves, and removed when they leave, on a clock you can measure. The leaver control is the one that fails quietly, because the person is already gone and nobody is watching the account. Federation through SAML or OIDC, single sign-on, and automated provisioning through SCIM are how mature organisations make the lifecycle a system rather than a memory.

The fourth is **privileged access** specifically. Administrators do not sit in a standing admin role all day. They elevate when they need to, for as long as they need to, and what they do while elevated is recorded. This is privileged access management: just-in-time elevation, break-glass accounts for emergencies, session recording, and time-boxed grants. The objective is not "we have PAM tooling." The objective is *no privileged action occurs without a time-limited, logged, reviewable elevation.*

5.3 Network security: assume the breach

The old network question was "can the attacker get in?" The modern question, the one a zero-trust mindset demands, is "once the attacker is in, how far can they get?" NIST SP 800-207 describes zero trust without implicit trust based solely on network location or asset ownership. Authentication and authorisation precede access to a resource. For a company whose entire estate is API calls to AWS, the network *is* already hostile by design.

Segmentation is the engineering of that mindset. Tessera's VPCs, subnets, security groups, and network ACLs should carve the estate into zones that contain blast radius. Production separate from staging. Customer-facing services separate from internal tooling. Databases reachable only from the application tier, never from the open internet. Each of those is a control; the objective is that *an attacker who compromises one component cannot traverse to another without a fresh access decision.* That is the difference between a breached container and a breached company.

Firewalls and security groups are the mechanism, but they are only as good as their rules, and rule drift is where segmentation goes to die. The rule opened for a vendor demo eighteen months ago and never closed. The `0.0.0.0/0` that someone applied to make a test pass. The database port exposed to the office range because a developer wanted to work from home. The objective is not "we use security groups." It is *every rule is justified, scoped to least access, and reviewed on a schedule*, which is a test you can actually run against the live configuration.

5.4 Cryptography and key management: the control that fails silently

Encryption is where auditors go wrong, because encryption looks finished. The dashboard says "at rest: enabled." The browser shows the padlock. Do not tick the box and move on.

Encryption at rest and in transit is the baseline, not the achieve-

ment. The achievement is **key management**, and it is where a cryptography control that looks perfect can be substantively broken. AWS Key Management Service (KMS) and hardware security modules (HSMs) exist to keep keys out of the data they protect. Customer-managed keys give Tessera control over who can use a key and when, through policies and grants that are themselves auditable. Key rotation introduces new key material but does not by itself revoke access or neutralise exposed historical ciphertext. AWS documents (https://docs.aws.amazon.com/kms/latest/developerguide/rotate-keys.html) that KMS retains earlier material for decryption; investigate exposure and permissions separately. Separation of duties limits the damage of a rogue insider. ISO 27001 A.8.24 (use of cryptography) points here, and the Essential Eight's expectations on backups and data protection lean on the same foundation.

Now picture the failure. Encryption is enabled on every S3 bucket. The dashboard is green. But the application role that reads customer data holds a KMS grant for a single key used by *every tenant*. One compromised token, one over-permissive policy, and the attacker decrypts everyone's data at once. This is an application-role compromise with decrypt permission, not storage theft alone. Test those threat models separately; the presence of encryption does not prevent misuse of an authorised decrypt path. This is the silent failure, and it is exactly the kind of gap a control objective, not a control list, will catch.

5.5 Multi-tenant SaaS: isolation is the whole product

Tessera is a multi-tenant SaaS. Customers share the same application, the same databases, the same infrastructure. The product they are paying for is, at root, the promise that they cannot see each other. Get tenant isolation wrong and the problem is existential.

Layered controls enforce tenant isolation: per-tenant identity and namespace boundaries in IAM, row-level or logical separation in

shared data stores, and, for the most sensitive work, per-tenant encryption keys with separately controlled decrypt permissions. Whether an administrator can recover plaintext depends on the architecture and effective permissions. The classic failure has a name: insecure direct object reference, where a request for `/api/tenant/1043/data` is honoured for an authenticated user who belongs to tenant 1077, because nobody checked the relationship. IDOR is the silent failure of multi-tenancy, and it is widespread because it fails open: the request succeeds, the log looks normal, nobody is alerted.

State the tested boundary and threat model. For E11, an ordinary authenticated tenant A user must not read tenant B's record by changing an API identifier; unauthenticated requests must also be denied. That is testable. It does not cover compromise of a trusted application role, an administrator, every interface or every error path.

Customer-managed KMS keys and bring-your-own-key arrangements do not automatically prevent the service from decrypting. Inspect key policy, grants, service integration and who can alter them. A design in which only the customer can decrypt is a different architectural claim and needs its own evidence.

5.6 The shared-responsibility line: who secures what

Underneath all of this is a line that determines who is responsible for what, and Tessera sits on the wrong side of it more often than its diagram suggests. AWS operates on a shared-responsibility model. AWS secures the cloud itself; Tessera secures what it puts in the cloud. That line bounds your entire technical audit, because you can only test what Tessera owns, and a great deal of what looks like "AWS's problem" is actually Tessera's.

AWS secures:

- the physical data centres, hardware, and networking;

- the virtualisation layer, and the regions, Availability Zones, and edge locations;
- the managed services' underlying platforms.

Tessera secures, in the cloud:

- customer data, and its classification and handling;
- IAM users, groups, roles, and policies;
- the application code and its third-party dependencies;
- the guest operating system and AMIs where the service is self-managed;
- network configuration, VPCs, security groups, and routing;
- client- and server-side encryption, key management, and the configuration of every managed service it switches on.

And because Tessera is itself a service provider, there is a third line. Tessera's customers trust Tessera for application-layer security and tenant isolation, while they keep responsibility for their own users, their own tenant configuration, and the data they choose to put in. A multi-tenant SaaS inherits a shared responsibility on both sides.

The shared-responsibility gap is the assumption that AWS covers something Tessera actually owns. "Encryption is AWS's job." "Patching is managed, so we're fine." "The region is resilient, so we don't need backups of our own." Each is an illustrative assumption to check against the selected service and its responsibilities. ISO 27001 Annex A.5 covers supplier and cloud-service relationships precisely because this line is where assurance leaks out. Your audit has to draw the line explicitly, on Tessera's own architecture, and test Tessera's implementation and oversight, including the adequacy and limits of provider assurance.

> ⚠ Watch out: 'it exists' is not 'it works'
>
> Two traps run through every technical audit, and they are the same disease: confusing the surface with the substance.
> The first: *a control that exists is not a control that is configured correctly.* Encryption is on, but decrypt permissions exceed the stated isolation requirement. MFA is enforced, but the SMS

fallback is enabled. Security groups exist, but the database is open to `0.0.0.0/0`. Each looks compliant on a dashboard. None meets its objective. Always ask what "good" looks like, then test for that.
The second: *a control someone else owns is not a control you can assume.* AWS secures the hypervisor. It does not secure your IAM policies, your application code, your key grants, or your patch cadence on self-managed components. Your authority may permit reliance on provider reports rather than direct provider tests. Evaluate that reliance and Tessera's complementary controls. If you cannot point to who owns a control, you have found a gap, not a comfort.

Tessera Case: What "good" looks like for tenant isolation

Use E11's ordinary-user threat model. A request by tenant A's user for tenant B's record must be denied, and the decision must be traceable in the application and access logs. Run only the authorised, isolated test with synthetic records.

The three supplied results meet their expected outcomes: own-tenant access returns the expected record; cross-tenant access is denied; unauthenticated access is denied. Corroborating logs agree. Record **P01: concern cleared within the tested boundary**. No failure should be invented merely because the opening diagram looked polished.

The result does not prove that an application administrator cannot extract data. That requires a separate objective and test, as do batch exports, alternate APIs and privileged service roles.

AI Field Note: From a generic list to a testable objective

An illustrative draft concludes, "All data is safe because KMS is enabled." Replace it with two questions: can a party with storage access but no decrypt authority recover plaintext, and can an application role exceed its permitted tenant boundary? Different evidence addresses each. Use E11 only for the request

cases it actually tests.

! Auditing AI: The AI estate is now part of the technical estate

The fixed case supplies evidence about Tessera's support assistant, which reads customer tickets and drafts replies. A customer-facing summarisation feature would raise similar questions but is not an additional tested system in SDA-2026.1. These are not experiments on a slide. They are workloads with identities, data access, and failure modes, and they sit squarely inside this chapter.

Treat them like any other component. The support assistant has a service role: what can it read? If it can see every tenant's tickets when it only needs the active one, that is a least-privilege failure identical in shape to any other. The product feature sends customer data to a model: what is sent, what is retained, and does the model provider train on it or promise not to? That is a data-minimisation and key-boundary question, and it foreshadows Chapter 9's privacy work. For any such deployment, ask about its vendor: which model, which version, and what does that vendor's SOC report actually cover? That is supplier assurance, the A.5 cloud-services territory Chapter 3 flagged.

The objective for an AI workload has the same shape as for any other: *the AI system cannot exfiltrate or act on data it has no business reason to touch, and every action it takes is attributable.* Test it the same way: enumerate the role's permissions, trace what data crosses the model boundary, and check the logs that record model calls. Some organisations also use AI to triage alerts or flag anomalies. When you audit those, you are back in territory Chapter 7 takes up in full: can you trust a control whose evidence an AI produced? For now, the discipline is the one this chapter teaches. State what good looks like, then go and try to break it.

 Evidence Locker: lock this in (Engagement milestone 5)

Time: 20 minutes. No AI required. Reproduce E11's three-row expected/observed result table and state a bounded conclusion. Then propose one additional test for a privileged application role, naming the required authority and safe environment. Add a cryptography objective that distinguishes storage-only theft from abuse of decrypt permission.

5.7 The question, answered

Technical assurance starts with a defined objective, a threat model and evidence of the tested decisions. E11 clears a specific concern without establishing universal isolation. The next chapter places those technical objectives within people, physical and management-system controls.

Chapter 6

Assess? Physical, People, and ISMS Controls: Preliminary Readiness

How much can you honestly say about a company you have only ever read about?

Tessera Case: Act I closes

Act I has examined the mandate and selected design records, especially E01–E03. The policies name responsibilities and expected performance. They also contain a two-hour/24-hour conflict and unsubstantiated "implemented" statuses. You can identify those design issues now; historical operating records are released in Act II for this staged exercise. Real audits need not defer interviews or operating evidence for six weeks.

6.1 What Act I let you do

Chapter 5 taught you the technological control objectives: access, network, cryptography, the AWS shared-responsibility split. Those sit in Theme A.8, the thirty-four technological controls. This chapter assesses the other three families the 2022 standard clusters controls into, plus the management system that holds them together.

The **people** controls (Theme A.6, eight controls) govern the human side: who you hire, what you make them agree to, how you train them, and what happens when they leave. The **physical** controls (Theme A.7, fourteen controls) govern offices, devices, and the environment they sit in. The **organizational** controls (Theme A.5, thirty-seven controls) are the largest family, and they sweep up everything that is neither purely human nor purely physical: policies, asset management, supplier relationships, classification, and the cloud services Tessera runs on.

Around all ninety-three controls sits the ISMS itself, the management system defined in Clauses 4 through 10 of ISO/IEC 27001: context, leadership, planning, support, operation, performance evaluation, and improvement. The controls are the body. The ISMS is the nervous system that makes them move.

A review restricted to policies establishes aspects of design. Remote inspection of reliable operating records can support an operating-effectiveness conclusion. State the limits of the supplied evidence and the claim it can support.

6.2 Physical and environmental security

Tessera runs on AWS, which buys them a tidy advantage: the physical security of the data centre is largely AWS's problem, attested through AWS's own certifications and the shared-responsibility split you learned in Chapter 5. Tessera does not secure the racks their instances live on. That does not leave them with nothing to secure.

They have a Perth office and staff laptops and phones that leave the building every evening. They may also have a small co-location rack for low-latency work, or a development box under someone's desk that nobody documented. Physical controls (A.7.1 through A.7.14) ask the unglamorous questions that decide whether any of that matters: is the perimeter secured, is access controlled and logged, are visitors managed, is the server cupboard locked, is equipment protected against fire and flood and the cleaner who unplugs the router to plug in a vacuum cleaner.

The desk read gives you Tessera's physical security policy, the badge-access procedure, the visitor-management process, the clear-desk and clear-screen standard, and the equipment-disposal procedure. Read together they describe an office that sounds disciplined. Badge access is "enforced 24/7." Visitors "must sign in and be escorted." Clear desk is "mandatory." Media disposal "follows a certified destruction process."

Notice the verbs. *Enforced, must, mandatory, follows*. Those are promises, and a promise is an assertion. From those policies alone you cannot confirm the badge reader at the side entrance actually denies a revoked card, that the visitor log carries a real signature for yesterday, that the fire-suppression system was serviced when the maintenance record claims, or that the back door near the loading bay is not propped open with a recycling bin every afternoon so the smokers can get back in. You have read what should happen. You have not seen what does.

6.3 HR security: the employment lifecycle

People controls are where organisations hurt themselves most predictably, because people are a lifecycle, not a state. A.6 makes that explicit. There is a moment a person joins, a long stretch in the middle where their role and access drift, and a moment they leave. Each transition is a control point, and the controls (A.6.1 screening, A.6.2 terms and conditions, A.6.3 awareness and training, A.6.5 responsibilities after termination or change, A.6.6 confidentiality agreements, and the rest) cluster around the joins.

Onboarding is the first gate. Screen candidates before employment, have terms signed before you grant access, put confidentiality agreements in place before the new starter sees customer data, and deliver security awareness training before they can do damage. The control objective is simple: nobody gets the keys before they have been checked and have agreed to the rules.

Role change is the silent one. A support engineer becomes an SRE and picks up production access. A developer moves into a team that

handles payment data. Each move should trigger an access review, because the permissions that were correct last quarter may now be excessive. The work is invisible and has no deadline, and so it is exactly the control that quietly stops happening.

Offboarding is the one that ends up in breach reports. When someone leaves, the clock starts on every minute their access stays alive after their last day. Return of assets, revocation of logical and physical access, handover of responsibilities, a final reminder of confidentiality: the offboarding checklist (A.5.18 for access rights, A.6.5 for continuing responsibilities, and A.5.11 for return of assets) is short, well-understood, and routinely incomplete.

E03 supplies the revocation deadlines and E05 later supplies checklist-design facts. Do not infer complete credential coverage from the existence of a sign-off field. Request termination, ownership and disable records, and reconcile them. Those records can be inspected remotely; physical attendance is not required for the arithmetic.

6.4 Asset management

You cannot protect what you have not inventoried. Asset management is the unsexy foundation under most other controls, and in the 2022 standard it lives largely in the organizational family: the inventory of information and associated assets (A.5.9), acceptable use (A.5.10), return of assets (A.5.11), classification (A.5.12), and labelling (A.5.13).

The desk read gives you Tessera's asset register and their classification scheme. The register should list the systems, the data stores, the devices, and the information that flows between them, each with an owner. The classification scheme should tell you which of that information is public, internal, confidential, or restricted, and what handling each tier demands.

An asset register can miss an unreturned laptop, an abandoned database or unclassified customer records. These are examples to investigate, not additional findings in the fixed case. The regis-

ter alone cannot establish completeness. Compare it with reliable discovery, procurement and disposal records, recording any blind spots.

6.5 Suppliers and the cloud Tessera sits on

Tessera relies on cloud services, a payment processor and a hosted support model. Supplier oversight is part of its ISMS. A service agreement establishes obligations; appropriate independent assurance and Tessera's own monitoring can support conclusions about performance.

Chapter 3 introduced the reliance worksheet. E09's payment-report period ends before the assessment cutoff and includes an exception. E07's AI-service bundle lacks executed processing terms. Do not assume all agreements are present merely because the supplier list exists.

! Auditing AI: The supplier you cannot inspect

For the support assistant, record the absent terms, uncertain regions and unverifiable training-setting screenshot. Request deployment-specific configuration and relevant vendor assurance. A public security page cannot establish actual handling of this account's data. Equally, unavailable evidence does not prove a vendor misused it. Carry the assurance gap into the privacy assessment.

6.6 The ISMS itself: governance on paper

Everything above is a set of controls. The ISMS is the thing that is supposed to make them work as a system. ISO/IEC 27001 devotes Clauses 4 through 10 to it: the organisation defines its context (Clause 4), leadership commits (Clause 5), it plans the risk treatment that selects controls (Clause 6), it supports the system with resources, competence, awareness, communication, and docu-

mented information (Clause 7), it operates it (Clause 8), evaluates its performance (Clause 9), and improves it (Clause 10).

The artefact that ties the controls to the system is the **Statement of Applicability** (SoA), required by Clause 6.1.3. The SoA lists the controls Tessera has chosen, the justification for each inclusion and exclusion, and whether each control is implemented. It is the index of the whole control set, and at the end of Act I it is the single document you have spent the most time with.

E03's SoA marks selected controls implemented without evidence references. Treat that status as an assertion needing support. The deadline conflict is already visible without operational access. Good formatting neither proves nor disproves control quality.

> ⚠ Watch out: the document confidence trap
>
> Ask what the particular document establishes. A policy can establish a requirement. A signed historical review can support operation for its population and date, subject to reliability checks. Neither supports an unrestricted conclusion about the whole ISMS. Record evidence type, scope and limits instead of declaring all documents either proof or worthless.

6.7 From documents to a preliminary opinion

A preliminary assessment should separate supported design observations, known design defects and operating questions that remain unanswered.

> ℹ AI Field Note: Summarising the policy set
>
> An illustrative summary of E03 says, "Offboarding operates within 24 hours because P-IT requires it." The premise establishes a deadline, not compliance with it. It also overlooks P-HR's two-hour rule. Correct the summary to name both criteria and request operating records. A model supplied with

reliable logs could assist their analysis, but still needs verification.

Tessera Case: Tessera's preliminary readiness opinion

The selected design records identify an ISMS scope and control responsibilities. They do not establish whole-ISMS readiness. E03 contains conflicting revocation deadlines and unsupported implementation statuses. Operational evidence for revocation, scheduled reviews and recovery remains to be tested. Supplier reliance and the support assistant's processing terms are unresolved.

We recommend completing the test programme and resolving the criteria conflict before making a Stage 2 recommendation. We have not assessed every requirement needed for Stage 1 or certification. This is a preliminary, limited-evidence readiness assessment.

That opinion identifies what the next phase must answer without assuming it will upgrade the result.

Evidence Locker: lock this in (Engagement milestone 6)

Time: 20 minutes. No AI required. Write your Act I assessment using E01–E03. For each claim, mark "supported design observation", "design issue" or "operating evidence needed". Include the conflicting deadlines and identify the next records to request. Avoid asserting whole-ISMS alignment from this selected extract.

6.8 The question, answered

Act I's outcome is a mandate, a criteria map and a test programme, with a bounded preliminary assessment. Act II adds the operating records needed to test selected claims. It may confirm a control, expose a failure or leave a question unresolved.

Part II

Act II · Prove: From Suspicion to Proof

Chapter 7

Prove? Evidence Collection and Testing

> *You can read your way to a suspicion. You can only evidence your way to an opinion.*

Tessera Case: Operating records arrive

Act I identified the revocation deadlines and the evidence needed to test them. E04 now supplies 48 leavers and their disable events. E05 adds incident and cause records. These are documentary operating evidence, even when read from a desk. Your task is to establish what each record supports and retain the reasoning so another reader can reproduce it.

7.1 The act break: from suspicion to proof

The staged release of records changes what you can conclude. It does not remove uncertainty. A timestamp may refer to the wrong event; a join may omit service credentials; a complete-looking export may cover only one business unit.

Access is a prerequisite for some procedures, not assurance in itself. Start with the objective and examine whether the available evidence can answer it. Missing evidence belongs in the result, rather than

being supplied through inference.

7.2 Four kinds of evidence

Observational evidence records what you saw: a revoked badge denied at a reader, or a tested access decision. It can be strong for that event. It may be less representative if staff alter their behaviour while observed.

Documentary evidence includes policies, logs, signed checklists, contracts and external reports. A policy supports a design claim; historical logs may support operation over a period. Reliability depends on creation, access, retention and alteration controls. "System generated" is not enough if the system can omit events or the administrator can rewrite its output.

Analytical evidence is work you perform on inputs: reconciliation, elapsed-time calculations, trend analysis or re-performance of a review. It can expose an inconsistency, but inherits errors in those inputs. Producing a spreadsheet yourself does not make the source complete.

Oral evidence includes interviews and explanations. It helps establish context and locate records. Memory, incentives and ambiguity can limit it. Corroborate consequential claims, especially when an objective record should exist.

There is no universal ranking that decides every case. Independent, contemporaneous and well-controlled records often deserve more weight, but relevance comes first. A current third-party report on the wrong service cannot answer a question about Tessera's leavers. A reliable internal event log can.

7.3 Sufficiency and appropriateness

Sufficiency concerns how much evidence is needed for the conclusion. **Appropriateness** concerns its relevance and reliability.

Evaluate both against the assertion, risk, period and intended reliance.

One event may settle a narrow claim about that event. It cannot establish that the same control operated for every event in a year. Conversely, a large collection of irrelevant screenshots adds little assurance. State the population and what the evidence actually covers.

A screenshot without account, time or provenance may still be a lead. It is weak support for a deployment-specific claim. A summary can help navigate raw records; preserve and inspect the underlying records before relying on details that summarisation might omit.

7.4 Sampling: why you cannot test everything, and how to size what you do

Define the population before selecting items. For the fixed case, it is all 48 departures from 1 June 2025 to 31 May 2026, including their separately managed keys. The pack stipulates reconciliation with payroll for the exercise. In real work, obtain the independent population, inspect exclusions and reconcile identifiers yourself.

For a large population, **attribute sampling** tests whether each selected item meets a defined condition. The sampling design must say how items are selected, what deviation means, how much sampling risk is accepted and how exceptions affect the conclusion. A convenience sample does not support a statistical confidence claim.

7.4.1 A numerical example

Consider a separate, large population of similar independent events. Suppose you expect no deviations, want a zero-deviation acceptance design and choose a tolerable rate of 5%, with a one-sided sampling risk of 5%. If the actual deviation probability were 0.05, the chance of observing zero deviations in n independent trials would be 0.95^n.

Choose the smallest n for which:

$$0.95^n \leq 0.05, \qquad n \geq \frac{\log(0.05)}{\log(0.95)} = 58.404\ldots$$

Round up to **59**. With zero observed deviations, the one-sided exact binomial upper bound is approximately **4.95%**. This is not a claim that the control is 95% reliable or that the probability of a breach is 5%.

The calculation assumes a binomial model and suitably independent representative selection. A finite population sampled without replacement requires an appropriate finite-population method; clustered events and different risks may require stratification or another design. If deviations are expected or found, this zero-acceptance example is not a complete evaluation plan. Agree the method and decision rules before drawing a sample.

7.4.2 Why Tessera uses a census

There are only 48 leavers, and the key-coverage question is important enough to inspect each. We test **48 of 48: a census**, not a 59-item sample compressed into a smaller population. A census removes selection-based sampling uncertainty for those recorded items. It does not remove missing-population, recording, procedure or interpretation error, and it does not predict future operation.

7.5 The five testing procedures

Inquiry: ask how a record was created and where exceptions are handled. Record what was claimed and what still needs corroboration.

Observation: watch an authorised control execution. Record the environment, participants and conditions; do not imply that the observed event represents an untested year.

Inspection: examine the relevant records or assets. For revocation, establish whether an event means disablement, deletion, last use

or merely a request. A key's "last used" timestamp does not prove when the key was revoked.

Re-performance: independently repeat a control or check, within the approved scope. Reconcile the complete leaver list with credential ownership and disable events rather than relying solely on a signed checklist.

Re-computation: check arithmetic, such as elapsed time and exception rates. Keep timezone and boundary conventions explicit. A two-hour rule means elapsed time no greater than two hours here; a result exactly at two passes.

These procedures answer different questions. Re-performing a calculation with incomplete inputs is not stronger than a reliable source record merely because it appears later in this list. Combine methods to address the assertion and its principal failure modes.

> ℹ AI Field Note: AI drafts the sampling plan and the test steps
>
> An illustrative draft proposes "test 25 leavers, verify manager notification, and confirm that old accounts are disabled today." The sample has no stated design. E04 is small enough for a census. Manager notification has no supplied event record and is not the revocation criterion. A current-state check cannot establish a past disable time. Replace the steps with an ID reconciliation, inspection of both credential families and elapsed-time calculations against both historical policies.
> The correction is checkable from the pack; no forecast about how every model behaves is needed.

7.6 Chain of custody

Record who obtained each item, when, from which system and by what query or export. Retain timezone, filters, permissions and transformations. Preserve the original and work on a controlled copy. Log transfers and restrict access according to the engagement's

retention policy.

A SHA-256 digest can detect a change relative to the recorded digest. It cannot tell you whether the original extract was truthful, complete or collected by the claimed person. Protect the manifest as well as the files. A digest invented for an illustration is not a reproducible checksum.

The book's source provides full checksums for its electronic teaching records. Those are packaging-integrity checks, not forensic provenance. For E04, use the manifest's synthetic-source description and capture date; do not record the author as a real-world auditor who extracted an actual client log.

7.6.1 One reproducible working paper

For **L007**, termination is 9 January at 16:00 AWST. Identity access was disabled at 17:00 that day. The separate key was disabled on 25 February at 16:00: **47 days = 1,128 hours** later. The latest disable event determines full revocation. It exceeds both P-IT's 24-hour and P-HR's two-hour historical deadlines.

For **L044**, the key delay is six hours. It passes P-IT and fails P-HR. That is why silently choosing the less demanding policy changes the result.

For the full population, three records exceed 24 hours: L007, L019 and L031. Four exceed two hours: those three plus L044. Record **3/48 = 6.25%** and **4/48 ≈ 8.33%**, each with its criterion. These are observed deviations in the supplied historical population, not probabilities of misuse or a future breach.

7.7 Auditing AI: can you trust a log an AI produced?

Distinguish a deterministic event recording that a model was called from the model's generated account of what happened. A generated summary may omit, misstate or infer details. Compare it with the

original event, the action actually taken and any downstream state change.

To evaluate an AI-assisted alert decision, define the desired decision, relevant classes and an independently reviewed reference set. Preserve uncertain labels and disagreements. Measure missed incidents as well as false alarms; a high overall accuracy can conceal failure on rare serious cases. Record model/version, configuration, period and operating context.

The fixed pack does not supply an alert-evaluation dataset, so it supports no conclusion about Tessera's anomaly detector. Treat this as a method extension. Do not add a successful AI-control test to the final opinion unless the underlying inputs and results exist.

7.8 Interviewing for evidence

Prepare from the objective. Ask an open process question, then request an example and its record. "Walk me through the last contractor departure" is more useful than a question that supplies the desired answer.

Keep three columns: claim, record requested, corroborated result. Differences between accounts can reflect scope, dates, memory or process variation. Investigate them rather than deciding in advance which person is evasive.

The interview guide provides a paper dialogue and optional live-site route. A difficult conversation is not proof of a defective control. A fluent answer is not proof of a sound one.

 Evidence Locker: lock this in (Engagement milestone 7)

Time: 35 minutes. No AI or code required. Test all 48 E04 rows. Retain the population definition, policy-specific result counts, four exceptional IDs, a full L007 calculation and a provenance note. Separately reproduce the 59-item sampling example with a calculator, or explain its assumptions from the worked calculation. Label the actual case test a census.

7.9 The question, answered

A supported result states what was tested, what the records show and what remains uncertain. The next chapter uses these results to assess policy compliance and review coverage.

7.10 Take it to the AI

Optional, after the paper test:

> **Role:** Review a trainee's audit calculation.
>
> **Task:** Check whether a proposed sample and conclusion follow from the supplied facts.
>
> **Context:** The complete fictional population contains 48 leavers. Three exceed 24 hours; four exceed two hours. All 48 were tested. A draft says "a statistically derived sample proves a 6% chance of a future breach."
>
> **Format:** Identify each unsupported claim, correct the arithmetic and give a bounded two-sentence conclusion. Use no additional case facts.

Check that the response separates census, historical deviation and future incident risk. A correct calculation still needs the source records behind it.

Chapter 8

Comply? Policy Evaluation: From Published to Proven

A policy that nobody follows is not a control. It is a PDF.

Tessera Case: The library, reopened

Act I identified policy obligations and a conflict between revocation deadlines. The operating records now let you test those obligations. Keep design issues and operating results distinct, and preserve the population and cadence of each review.

8.1 What full access changes

Act I recorded design observations and evidence gaps. Act II adds operating records and permitted tests. You can now interview the people named in the policies, log into the systems the policies describe, pull the logs the policies say are kept, and read the meeting minutes where the controls are supposed to be reviewed. Each is a different kind of evidence, and Chapter 7 covers how to weigh it. Point it at the policy set itself.

Policies are the soft tissue of an information security management system. They are also the part an organisation finds easiest to produce and hardest to live by, because writing a policy is a writing

problem and following one is a behaviour problem. A fast-growing company like Tessera can write an excellent policy library in a quarter with a good consultant and a long weekend. It cannot build the habits that make those policies operate in anything like the same timeframe. The gap between the two is where this chapter lives.

8.2 Compliance is not effectiveness

Compliance means meeting applicable requirements, which may themselves require effective operation. **Effectiveness** concerns achievement of the intended result. A well-written policy can establish a requirement without demonstrating either operating compliance or effectiveness.

For example, P-REV requires a monthly privileged review. A signed policy with no review record does not demonstrate compliance with that requirement. A completed review might meet its documented cadence but still miss service credentials, undermining the objective.

Assess design, implementation and operation separately. The management system's performance-evaluation requirements and selected review controls need evidence of actual evaluation. Do not label the whole estate "compliant on paper" merely because documents mention the right topics.

8.3 The A.5 backbone

ISO/IEC 27001:2022 clusters its ninety-three controls into four themes, and Theme A.5, the organizational family, is the largest: thirty-seven controls, A.5.1 through A.5.37. Where the people controls (A.6) govern the human lifecycle, the physical controls (A.7) govern offices and devices, and the technological controls (A.8) govern systems, A.5 governs the organisation itself: its policies, its roles, its assets, its suppliers, its information, its incidents, and its compliance.

Think of A.5 as the governance backbone. It opens with the policies themselves (A.5.1, policies for information security) and the roles

accountable for them (A.5.2, A.5.3, A.5.4). It sweeps up asset management (A.5.9 through A.5.13), access governance (A.5.15 through A.5.18), supplier and cloud relationships (A.5.19 through A.5.23), incident management (A.5.24 through A.5.28), continuity (A.5.29, A.5.30), legal and privacy obligations (A.5.31 through A.5.34), and the review and compliance machinery meant to hold it all together (A.5.35, A.5.36, A.5.37). Strip out A.5 and the other three themes have nothing to attach to, because A.5 is where the organisation says what it will do. The other themes are where it does it.

That makes A.5 the natural home for the policy-effectiveness question, and it makes the Statement of Applicability's status column the first place an auditor looks for the gap. In Act I you read that column and noted, with discipline, that "implemented" is an assertion. In Act II you can test it. Pick a control, take the policy at its word, and find out whether the word is true.

8.4 From published to operating: how to test a policy

Testing whether a policy operates is a four-step move, and it works on any A.5 control.

Read the policy for its operational claims. Most policies mix aspiration with obligation. Your job is to extract the obligations: the things the policy says *will* happen, on a cadence, by a named owner, to a defined standard. "Access rights are reviewed quarterly" is an operational claim. "Security is a core value" is not. Underline the claims. Each one is a test waiting to be designed.

Identify the evidence the claim would produce if it were true. A quarterly access review leaves a footprint: a signed review record, a ticket, a change log, a meeting minute. A 24-hour leaver-revocation control leaves a footprint: a revocation timestamp in the identity provider, correlated against the HR termination date. If the control operates, the world looks a particular way. Decide what that way is before you go looking, so you test the claim rather than your own

surprise.

Gather the evidence, then compare it to the claim. This is where full access earns its keep. Pull the population (every leaver, every privileged account, every supplier), not the sample the client offers you. Trace the operational claim through the population. Count the exceptions.

Form a judgement tied to the criterion. State whether the tested items meet it, the exception count and what that implies about effectiveness within the tested scope. A control that operates for 95 per cent of the population and fails for 5 per cent is not "mostly compliant." It is a control with a measured exception rate, and the consequence of that rate depends entirely on which 5 per cent.

Use the procedures in chapter 7: inquiry, inspection, observation, re-performance and re-computation as appropriate. Their value depends on the assertion and source quality. Preserve the record behind each result.

Tessera Case: A.5.18 access rights, tested

Use E03, E04 and E06, keeping the populations separate.

The leaver test, F01. Both approved historical deadlines apply to the same full-revocation objective. Testing E04 yields three exceptions to 24 hours (L007, L019, L031) and four to two hours (also L044). The worst is L007's 47-day key. E05 supplies incident evidence separately; an exception rate alone does not establish misuse.

The quarterly review test, F02. P-REV requires ordinary-access reviews for AWS, Workspace and Slack each quarter. E06 contains signed records for AWS and Workspace for the quarter ending March 2026, but none for Slack. The supplied result is incomplete quarterly coverage of the three-system population.

The monthly privileged test, also F02. January–March 2026 review evidence is absent for the separate privileged population, including service credentials. A calendar reminder does not establish completed reviews. Keep this monthly requirement distinct from the quarterly ordinary-access requirement.

The authorisation concern, P01. E11's three requests met their expected decisions. This bounded pass belongs in the record alongside the failures. It does not close F01 or F02 because it tests different assertions.

Management's June 19 policy revision aligns the deadlines to two hours prospectively. E10 supplies the limited follow-up; it does not erase the historical exceptions.

> ⚠ Watch out: resolve conflicting criteria openly
>
> Report the result under each approved rule while seeking an authorised interpretation or correction. Do not choose the weaker requirement because it produces fewer exceptions. Record the decision's effective date. A new rule does not automatically rewrite the criteria that applied during historical testing.

> ℹ AI Field Note: The policy-gap analyst
>
> An illustrative summary says "quarterly privileged reviews were missed twice." E06 says something different: incomplete quarterly ordinary-access coverage, and no supplied monthly privileged reviews for January–March. Preserve cadence, population and period in the correction. A polished summary that merges them changes the finding.

> ❗ Auditing AI: The policy that forgot the AI
>
> E07 describes an enabled support assistant missing from the processing register, with incomplete terms and unverified settings. P-PRIV requires that information before enablement. Assess actual deployment against that requirement. An acceptable-use policy can also need revision as tools and data flows change; its existence is not evidence that a particular deployment was approved.

 Evidence Locker: lock this in (Engagement milestone 8)

Time: 25 minutes. No AI required. Build a four-row gap map: historical revocation under P-IT, historical revocation under P-HR, quarterly ordinary review and monthly privileged review. Give criterion, population/period, evidence IDs, result and finding ID. Explain why E11's pass cannot close either access finding.

8.5 The question, answered

The policies contain testable obligations. E04 establishes historical exceptions, while E06 cannot substantiate the required review coverage. Keep F01 and F02 separate and carry both forward. The next chapter follows the assistant's personal-information flow.

Chapter 9

Protect? Data Protection and Privacy

Security asks whether the wrong hands reached the data.
Privacy asks whether you had the right to hold it at all.

Tessera Case: follow the ticket

E07 supplies a support-assistant data flow. A ticket containing a customer's name, work email and attachments passes to an external model service. The processing register omits that service, the executed processing terms are unavailable and a training-setting screenshot cannot be tied to the deployed account. You have enough evidence to identify an assurance gap. You do not have enough to invent what the vendor did with the data.

9.1 The crown jewel, and why privacy is not security

Security protects confidentiality, integrity and availability. Privacy also concerns how information about people is collected, used, disclosed and retained. Encryption can reduce exposure while leaving an inappropriate collection or use unresolved. Conversely, a careful collection notice does not prevent an access-control failure.

For this case, E05 stipulates that Tessera is covered by the relevant Australian privacy obligations. In real work, establish jurisdiction, entity coverage, exemptions and any additional sector or contractual duties before applying a checklist. A turnover shortcut alone is not a full applicability assessment.

The auditor's role is to map facts, test controls and identify uncertainty. Escalate consequential legal interpretation to a qualified privacy adviser. This chapter is an introductory guide to selected obligations, not a legal opinion or an exhaustive APP assessment.

9.2 The Australian Privacy Principles

The thirteen Australian Privacy Principles address the handling of personal information by covered entities. The following questions orient this engagement; other principles may also apply.

APP 1: how does the organisation manage privacy openly and transparently? Check governance and whether the policy reflects actual handling.

APP 3: why is the information being collected, is collection reasonably necessary for the organisation's functions, and are the applicable conditions met? Sensitive information generally attracts additional consent requirements, subject to exceptions. Do not infer permission for every attachment merely because the ticket system accepts it.

APP 5: what reasonable steps notify people, or ensure their awareness, of relevant collection matters? Timing matters: generally at or before collection, or as soon as practicable afterwards. A privacy policy link is not automatically an adequate collection notice. Compare the actual interaction with purposes, usual disclosures and relevant overseas-recipient information. See OAIC's APP 5 guidance (https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-5-app-5-notification-of-the-collection-of-personal-information).

APP 6: is a use or disclosure for the primary collection purpose, or

does an exception permit a secondary purpose? The reasonable-expectation exception requires the secondary purpose to be related to the primary purpose, or directly related for sensitive information. Consent and other specified exceptions can also apply. "The person would expect it" alone is incomplete. Record purpose, relationship, sensitivity and the applicable basis; do not ask a model to decide a legal basis from a product description. See OAIC's APP 6 guidance (https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-6-app-6-use-or-disclosure-of-personal-information).

APP 8: does the arrangement involve disclosure to an overseas recipient, and which obligations or exceptions apply? The next section develops this question.

APP 11: are reasonable technical and organisational steps protecting the information? Where it is no longer needed for a permitted purpose, assess destruction or de-identification duties and exceptions, including applicable retention requirements. Do not delete records merely because one business use ended. See OAIC's APP 11 guidance (https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-11-app-11-security-of-personal-information).

These questions require evidence of practice: the collection screen, the deployed integration, the executed terms and the actual retention controls. Policy text alone is insufficient.

9.3 The Notifiable Data Breaches scheme

The NDB scheme distinguishes suspected eligible breaches from established notification duties. Broadly, unauthorised access, disclosure or qualifying loss must be likely to cause serious harm, with relevant remedial-action provisions and exceptions considered. Loss requires examining the likelihood of unauthorised access or disclosure as well.

On reasonable grounds to suspect an eligible breach, undertake a reasonable and expeditious assessment and take all reasonable

steps to complete it within **30 calendar days**. This is a statutory assessment duty, not permission to wait 30 days or a general 30-day notification deadline. When there are reasonable grounds to believe an eligible breach occurred, notify as required as soon as practicable. OAIC's NDB guidance (https://www.oaic.gov.au/privacy/notifiable-data-breaches/preventing-preparing-for-and-responding-to-data-breaches/data-breach-preparation-and-response/part-4-notifiable-data-breach-ndb-scheme) explains the assessment and notification pathways.

Use E05's supplied adviser assessment for INC-01. It records why this incident was eligible and that notifications occurred. L044's late revocation, by contrast, establishes a policy exception without supplied evidence of misuse or serious harm. Do not assign the same legal outcome to both.

9.4 Cross-border disclosure and data sovereignty

An overseas API call is not automatically a disclosure attracting every APP 8 and section 16C consequence. Determine whether personal information is disclosed or remains under the entity's effective control in a use arrangement. Processing access, contractual controls and actual handling matter. Applicable exceptions can also affect the result.

Where APP 8.1 applies, reasonable steps concerning the overseas recipient and section 16C accountability need consideration. A contract can contribute to those steps; it is not a universal safe harbour. Read OAIC's overseas-information guidance (https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/handling-personal-information/sending-personal-information-overseas) and escalate uncertain arrangements.

Keep **residency** (where data is stored or processed), foreign access powers and permitted disclosure separate. An Australian primary database does not describe every support-access path, log store or

model endpoint. Conversely, an unknown region is an evidence gap, not proof that the least favourable region was used.

> ⚠ Watch out: importing a legal shortcut
>
> A draft that says "sign EU Standard Contractual Clauses and APP 8 is satisfied" skips the Australian analysis. The presence of European contract language does not settle Australian obligations. Identify the applicable regime, the actual arrangement and the evidence supporting the conclusion.

9.5 The Privacy Impact Assessment

A PIA investigates effects on people as a project or processing arrangement changes. Begin with the intended function and map the information through collection, storage, use, access, onward processing and deletion. Identify people affected, purposes, recipients, locations, retention and control responsibilities. Consult the relevant stakeholders and record residual uncertainties and decisions.

For the fixed exercise, create a compact PIA fragment from E07. A useful row separates **observed fact**, **requirement or question**, **risk to individuals**, **evidence needed** and **owner/action**. Do not put an invented answer in the evidence-needed column.

Tessera Case: F03, the support-assistant privacy gap

Criterion: P-PRIV requires documented flows, relevant notices, executed terms, verified settings, retention/deletion controls and incident escalation before enablement.

Observed flow: customer ticket → Tessera support system → hosted model → draft reply and prompt logs. E07 confirms personal information in the input; the vendor's processing regions and terms remain unconfirmed.

Notice and register: the collection interaction does not explain external AI processing and the processing register omits the assistant. Request an appropriate approved notice and register update; seek

advice on the actual APP 5 position.

Use and disclosure: record the support purpose and determine the vendor's permitted uses, access and retention. There is no supplied basis for asserting that vendor training occurred or that a particular APP 6 exception applies.

Terms and location: obtain executed deployment-relevant terms, recipient/subprocessor details and processing/access locations. Determine the use/disclosure analysis with the privacy adviser. Do not mark this row compliant on a generic marketing claim.

Training setting: the screenshot lacks an account ID and date. Request a traceable configuration export or appropriate vendor confirmation for this deployment. Until then, training opt-out is unverified.

Retention and incident handling: no approved prompt-log deletion schedule or tested deletion process is supplied; the runbook lacks a vendor-breach path. Define the required records and test the authorised process.

Status at cutoff: F03 remains open, rated high under E02 because a live customer-data flow lacks required governance and assurance. A drafted notice and a request for terms are progress, not closure. This rating is a readiness judgement against P-PRIV, not a finding that an eligible vendor breach occurred.

9.6 Data masking, minimisation, and secure deletion

Minimise the personal information needed for a task. Removing a name may not sufficiently de-identify a ticket if its free text, role or unusual circumstances identify the person. Use synthetic material for this book's tests. In a real engagement, treat masked or pseudonymised material according to its remaining identifiability and authorised use.

Deletion requires knowing the copies and retention rules. Consider live databases, prompt logs, replicas, backups and exports. A delete

button in the application does not establish destruction everywhere. Some records must be retained; document the basis and restrict access while retained. Test deletion with permitted synthetic markers where feasible, inspect system evidence and record any copies beyond the test's reach.

The ISO/IEC 27001:2022 areas relevant here include privacy (A.5.34), information deletion (A.8.10), data masking (A.8.11) and data leakage prevention (A.8.12). Do not describe all four as new in 2022: the privacy control has a predecessor. Exact requirements and implementation choices need the authorised editions and the organisation's selected controls.

9.7 The privacy of the AI you bolt on

Separate several failure mechanisms. Prompts can be retained in service logs, seen through support access, reused for training or exposed through application authorisation errors. Disabling training does not establish that logging, access and deletion are sound.

Training-related attacks also have different goals. Membership inference attempts to determine whether a record was in training; reconstruction or inversion attacks try to infer information about training data. Their feasibility depends on the model, access and data. Neither attack is a guaranteed recovery of every training record, and avoiding training on prompts does not remove unrelated inference-time disclosure risks.

For this engagement, the immediate task is narrower: verify the deployed data flow and controls named in P-PRIV. There is no supplied attack evaluation from which to report a measured model-privacy risk.

> ℹ AI Field Note: drafting the PIA data map
>
> An illustrative draft converts E07's incomplete screenshot into "training disabled, verified". Ask which record binds that setting to the deployed account and date. None is supplied.

Rewrite it as “training setting unverified; deployment-specific evidence required”. This correction preserves uncertainty without asserting that training happened.

 Evidence Locker: lock this in (Engagement milestone 9)

Time: 30 minutes. No AI required. Create the five-column PIA fragment from E07. Cover notice/register, purpose and handling, terms/regions, training verification, retention/deletion and vendor incident escalation. Use one F03 identifier with distinct subissues. End with the evidence needed for closure and the legal questions needing qualified advice.

9.8 The question, answered

The supplied evidence supports a privacy-governance and assurance finding, not a blanket verdict on every APP or proof of a vendor breach. Carry all F03 subissues into the final opinion until evidence closes them. Recovery is the next untested service promise.

Chapter 10

Recover? Business Continuity and Incident Management

When (not if) the region goes dark, the runbook you never tested is the plan you actually have.

Tessera Case: When the region fails

Full access has changed the kinds of question you can ask. At the outset of the engagement you would have been grateful for a continuity policy to read; now you ask to see the failover runbook and the result of the last time it ran. Tessera's CTO points you to a 47-page business-continuity plan and a diagram showing a primary region, a standby region, and an RTO of four hours. It looks exactly right. So you ask the only question that matters: *when did you last fail over, and what happened?* Pause for the answer and request the record. Silence tells you nothing reliable about whether the recovery capability works.

10.1 The break that is coming

Continuity and incident management are the controls that assume failure. A mature organisation treats the question as *when*, not

if: AWS regions fail, databases corrupt, ransomware encrypts, a contractor clicks the link. The discipline here is to survive those events, and to prove you can.

ISO/IEC 27001:2022 treats this seriously, and mostly inside the large organizational family. Information security during disruption (A.5.29) and ICT readiness for business continuity (A.5.30) are the two continuity controls, the latter new in the 2022 edition and worth a section of its own. Incident management is a five-control cluster: planning and preparation (A.5.24), assessment and decision on security events (A.5.25), response (A.5.26), learning (A.5.27), and collection of evidence (A.5.28). NIST CSF 2.0 gives the work two whole functions of its own: Respond (RS) and Recover (RC). The ASD Essential Eight, for its part, folds the same intent into its eighth and most underestimated mitigation: regular backups.

The posture shift of Act II matters here more than anywhere. In Act I you read the continuity policy and noted, correctly, that its design looked complete and that you could not tell whether any of it operated. Now you hold the runbook, the test schedule, the incident log, the backup configuration, and the people who would actually run it at 2am on a Sunday. The polished plan finally meets its evidence.

10.2 RTO and RPO: derived, not picked

The **Recovery Time Objective (RTO)** is a target interval for restoring the specified service after disruption. Define the start event and what counts as restored service. The **Recovery Point Objective (RPO)** specifies how far back in time the recovered data may be relative to the disruption.

Keep these separate from **maximum tolerable disruption**, the business-impact limit beyond which consequences become unacceptable. An RTO should leave room for required business resumption within that limit. A restored database alone may not constitute a restored service.

A business-impact analysis identifies affected processes, dependen-

cies and the consequences of interruption over time. It informs targets alongside commitments, feasible strategies and authorised risk decisions. Targets must be agreed and supported; a generic "industry standard" number is not a derivation.

E08 supplies the signed criteria for this exercise: RTO four hours, RPO fifteen minutes and maximum tolerable disruption eight hours. The contract separately promises 99.9% monthly availability. In a 30-day month, 0.1% is **43.2 minutes**, before applying the contract's exclusions. A four-hour qualifying outage would exceed that monthly budget. It does not follow that the SLA automatically sets an RTO of 43.2 minutes: examine service definition, exclusions, remedies, business impact and risk acceptance.

The auditor should make that exposure visible. Ask whether management understands the consequences of a recovery that meets its RTO yet misses its availability commitment. Do not silently alter either criterion to reconcile them.

> ℹ AI Field Note: Drafting the BCDR test plan
>
> An illustrative draft changes the case's RPO to one hour because that is a plausible SaaS target. E03 and E08 say fifteen minutes. Restore the agreed criterion before evaluating the test. A second draft concludes that a five-and-a-half-hour restore meets the four-hour RTO because it is below the eight-hour disruption limit. That confuses a recovery target with a business-impact ceiling.

10.3 How you test a plan: tabletop, simulation, failover

A plan that has never been exercised is a draft. ISO/IEC 27001 expects continuity controls to be tested, and the discipline in Act II is to establish not just that a test happened but that it tested the right thing at the right depth. Testing falls along a spectrum, and the deeper you go, the more it costs in time and risk, and the more

it proves.

Tabletop is a paper walkthrough. The team sits in a room, or on a call, and talks through a scenario: "Sydney is down, here is the runbook, what do you do?" It tests understanding, roles, decision rights, and whether the runbook reads the way someone under stress would need it to. It costs almost nothing, and it reliably surfaces the first category of problem: the plan nobody has read, the contact list with last year's phone numbers, the approval step that names a person who left the company. A tabletop can support conclusions about understanding and decision paths under the exercise conditions. It does not demonstrate technical restoration throughput or data integrity.

Simulation raises the stakes. The team runs a scenario against a realistic but non-production environment, with some actual mobilisation: pages go out, an incident channel opens, people log in to the recovery systems. Simulation tests the *process* under load: how fast the team assembles, how the runbook holds when the steps are real, where the confusion lives. It still does not touch production, which is what makes it the workhorse test for most organisations, run once or twice a year.

Failover is the real thing. The service is actually moved to the recovery environment, either in parallel with production or, in the most demanding form, by interrupting production to force the switch. A well-designed failover test can provide integrated evidence: that the standby database really has the data, that DNS really reroutes traffic, that the application really starts in the standby region, that the RTO is achievable and the RPO holds. It is also the test organisations avoid, because it is expensive, it is risky, and it can break the very thing it is meant to protect. So they do not run it, and then they tell you it would work.

An isolated restore can also test technical claims, including backup usability, throughput and application checks. State what it omits, such as production routing or live dependencies. A more disruptive test is not automatically better evidence for every question.

Agree the environment, authority, rollback, stop conditions and

acceptable business impact before any exercise. The auditor requests and observes authorised tests; this book does not authorise readers to fail over production. The speed of a witness's answer is not a substitute for the test record.

10.4 The region-failure audit

Tessera Case: The failover that has never failed over

E08 resolves the book's scenario version. Its signed BIA and policy set the targets. A draft diagram depicts a hot standby that the deployment inventory does not contain. The actual runbook uses a cold restore. That discrepancy needs correction, but absence of a standby alone does not prove recovery impossible.

The isolated exercise starts at **10:00** and passes application/dependency checks at **15:30**. Elapsed time is **5 hours 30 minutes**, exceeding the four-hour RTO by **1 hour 30 minutes**. The latest usable backup contains data through **09:20**, so the recovery-point gap at interruption is **40 minutes**, exceeding the fifteen-minute RPO by **25 minutes**.

The restored copy passed its supplied integrity checks. That positive result belongs in the record. It does not cancel the missed targets, untested production cutover and untested key-service dependency. Nor does a non-production result establish exactly how long a real regional incident would last.

Record **F04**, high under E02: the supplied recovery exercise misses P-REC's targets and leaves material dependencies unverified. No later successful test exists in the case. Management's planned July exercise is an action, not evidence of closure.

> ⚠ Watch out: availability zones and regions
>
> Multiple availability zones can reduce exposure to a zone failure while leaving regional dependencies. Inspect where the usable backups, replicas, keys and recovery tooling reside and

> what failures they are designed to survive. A cold restore can be a valid strategy if it meets the agreed objectives and is adequately tested. A diagram alone establishes neither deployment nor recoverability.

10.5 Incident response: the lifecycle you audit

Continuity is the slow failure: the region is down, we recover. Incident response is the fast one: we are under attack, or something is wrong, right now. The two share people and overlap in practice, because every incident has a recovery phase, but they answer different questions and they audit differently.

The familiar four-phase model, preparation; detection and analysis; containment, eradication and recovery; post-incident activity, comes from SP 800-61 Rev. 2. Revision 3 (https://csrc.nist.gov/pubs/sp/800/61/r3/final), published in April 2025, superseded it and integrates incident response throughout CSF 2.0 risk management. The older phase names remain a useful historical teaching aid, not the current publication's structure. Related ISO/IEC 27001:2022 control areas can guide evidence requests without implying exact equivalence: A.5.24 is preparation, A.5.25 is the assessment that decides an event is an incident, A.5.26 is the response, A.5.27 is learning, and A.5.28 is the evidence you collect along the way, increasingly load-bearing when the incident touches personal data and the Notifiable Data Breaches clock from chapter nine starts running.

The desk audit in Act I could confirm the IR plan existed and named a team. Act II asks whether it operates, and the test is the same as everywhere else: trace real events through the lifecycle. Ask for the last two or three security incidents and walk each one forward. Was it detected, by what, and how fast? Was it triaged and severity-assigned against the defined scale? Was the plan invoked, and is there a record of who did what and when: the incident channel, the paging history, the incident bridge notes? Was containment applied, and was the eradication complete or merely cosmetic? Was

recovery validated before the incident was closed? And the step organisations skip most: was there a post-incident review, and were its action items tracked to closure, or did they die in a spreadsheet?

The single most revealing test is the gap between events and incidents. Pull the security event log over the same window as the incident register and compare them. If the alerts fired and nothing was triaged, detection exists but response does not, and the control is broken in the place nobody looked. A plan that handles declared incidents beautifully while the queue of undeclared ones piles up is a control that works on paper and fails in practice.

! Auditing AI: when the detector decides for you

As a method extension, consider an organisation that connects cloud detection findings to automated response. The fixed case supplies no detector-evaluation or auto-remediation test, so this example adds no successful control result to Tessera's opinion. This is the modern shape of incident response, and it raises a question the lifecycle does not answer on its own: when a machine decides an event is benign, or fires a response on one, can you trust it?

The audit moves in two directions. First, tune and coverage: what is the false-positive rate, what classes of threat are in scope and (crucially) out of scope, and who reviews the detection logic and how often? An untuned detector drowns the team in noise until they mute it, which is functionally identical to having no detector at all. Second, the human-in-the-loop boundary: which automated actions run without approval, and is that list defensible? Endpoint quarantine can interrupt clinical, industrial or business-critical work. Assess each action's authority, blast radius, reversibility, dependencies and stop conditions; neither quarantine nor a production shutdown is universally safe. Ask to see the action that fired, the model's confidence, and the human review that followed. If the response was fully automated with no record, the control ran, but nobody can tell you whether it ran correctly. An AI that

> reports “all clear” is still a judgement, and a judgement with no reviewer is an unattended control.

10.6 ICT readiness for business continuity

A.5.30, ICT readiness for business continuity, is a 2022 addition, and it deserves to be named because it is easy to read past and because it does work the older “information security during disruption” control does not. A.5.29 says the organisation must keep information security working during a disruption: controls do not switch off because you are in a crisis. A.5.30 says something more demanding: the ICT services themselves must be ready to meet the continuity objectives the business has set. It forces the join between the BIA’s numbers and the technology that has to hit them, and that join is exactly where Tessera’s plan falls apart.

Readiness is a property you can test. It asks whether the chosen hot, warm or cold recovery strategy meets the objectives; whether the data replication actually runs and within the RPO; whether the runbook matches the infrastructure that is really there; and whether the people who would execute it have rehearsed. NIST SP 800-34 and ISO 22301 give the broader contingency and continuity disciplines their proper home, and ISO/IEC 27031 is the one aimed squarely at ICT readiness. For an auditor, A.5.30 collapses all of that into a single testable question: if the disruption happened today, on the estate as it actually stands, would the ICT services meet the objectives? For Tessera, the supplied exercise misses the agreed targets, and dependencies remain untested. That is the supported conclusion.

10.7 The question, answered

The supplied cold restore recovered an integrity-checked copy but missed both agreed targets. Production cutover and a key-service dependency remain unverified. F04 stays open; the evidence does not justify a promise of four-hour regional recovery.

E05 separately supplies one incident chronology and a privacy-adviser assessment. Trace detection, containment state, assessment and notification using those records. It does not establish that every incident in the period was identified or handled effectively.

 Evidence Locker: lock this in (Engagement milestone 10)

Time: 25 minutes. No AI required. Recompute E08's elapsed restoration time, recovery-point gap and SLA budget. Compare each with its own criterion. State one supported success and two limitations. Add F04 and its closure evidence request, then trace INC-01 from E05 without inventing additional incidents.

The next chapter turns the tested conditions into findings and an explicit closure ledger.

Chapter 11

Report? Findings and the Audit Opinion

What did we find, and how do we say it so the board acts?

Tessera Case: the report must preserve the evidence

The CTO asks for a one-page conclusion. Your working papers include historical access exceptions, missing review records, unresolved privacy terms and a recovery test that missed its targets. Management has also made changes. The report must distinguish tested progress from promises without losing any issue on the way to the board.

11.1 From evidence to a finding

A finding connects a requirement with an evidenced condition. State the relevant population, period and limitation. A policy exception is not automatically an incident; an incident does not establish failure of every control. Missing evidence may prevent an assurance conclusion without proving the underlying activity never happened.

Give each finding a stable ID. Use that ID in the test, management response, retest and final opinion. If wording changes, retain enough history to show that the underlying issue has not been replaced by

an easier one.

A finding can be reported before its root cause is fully established. Mark the cause as provisional or unknown and require investigation. Do not delay reporting a serious supported condition, or invent a cause, merely to fill a template.

11.2 The 5C+R format

This book uses **5C+R as an author-created working template**, not a universal certification-body marking scheme. Follow the actual engagement's reporting requirements. Here the five Cs are Criteria, Condition, Cause, Consequence and **Correction**; the recommendation records proposed corrective action and management's response.

Criteria: identify the requirement, its version and why it applies. P-IT and P-HR supply the operational deadlines in this case. A.5.18 is the related access-rights area; A.6.5 addresses continuing responsibilities. Do not put quotation marks around a paraphrase and attribute it to the standard.

Condition: state what the test found, including what it did not establish. "Three of 48 leavers exceeded 24 hours" is reproducible from E04. "Offboarding is bad" loses the period, population and threshold.

Cause: distinguish supported mechanism from hypothesis. E05 supports a missing key-owner step and unacknowledged handoffs for two exceptions. L044's six-hour delay has no supplied cause. An unresolved cause needs an owner and investigation, not a plausible sentence supplied by a model.

Consequence: explain the effect on objectives and obligations. Separate actual harm, plausible exposure and uncertainty. E05 provides realised misuse for L007; it does not establish misuse for the other exceptions.

Correction: address the detected problem, such as authorised revocation of a remaining credential or repair of an incorrect record.

Record owner, authority, deadline and evidence of completion.

Recommendation and response: propose or agree **corrective action**, which addresses causes and recurrence. Management owns implementation; the auditor evaluates the response and verifies the evidence within the agreed mandate. A checklist change alone is not proof that the revised workflow operates.

Correction and corrective action have different purposes. The distinction is consistent with ISO's quality-management vocabulary (https://www.iso.org/obp/ui?*escaped_fragment*=iso%3Astd%3Aiso%3A9000%3Aed-5%3Av1%3Aen).
The exact management-system requirements must still be checked in the authorised edition.

11.3 Root-cause analysis: the finding's centre of gravity

Repeated "why?" questions can help locate a mechanism, but they do not prove it. Test proposed causes against records and consider alternatives. If the handoff failed because a queue was inaccessible, training alone may not correct it. If a signed checklist omitted a separately owned key, enforcing the same incomplete checklist may reproduce the problem.

A fictional junior auditor writes "staff did not follow the process" and proposes refresher training. The reviewer asks which step failed, who owned it and how completion was established. E05 shows that the process did not cover key ownership and did not ensure an acknowledged handoff. The revised response needs those mechanisms addressed. It need not prescribe automation as the only possible solution.

Keep accountability clear without treating a person's name as a complete causal explanation. Equally, do not assume that every failure must have a purely systemic cause. Record the investigation, alternative explanations and evidence still missing.

11.4 Rating the finding: from guess to evidence

E04 establishes **3/48 = 6.25%** historical deviations against 24 hours, and **4/48 ≈ 8.33%** against two hours. These are observed rates in a census. They do not establish the probability of future misuse, a future breach or the proportion of all access controls that are ineffective.

E05 changes the consequence assessment: one retained key was used for unauthorised reads and the supplied adviser assessment records an eligible breach. No misuse is evidenced for the other records. Assess continuing exposure separately from the incident already realised.

Use E02's agreed readiness-priority rules. F01 is high because of the critical credential-coverage failure, realised misuse and incomplete verification of the revised process. That is this engagement's risk judgement. It is not an automatic ISO "major" classification based on a percentage. Preserve the original severity when recording remediation; closure status and residual risk are separate fields.

11.5 The offboarding finding, in full

Tessera Case: F01

Criteria: E03's P-IT v3.1 requires full revocation within 24 elapsed hours; P-HR v2.0 requires two hours. Both applied during the historical period without an approved precedence rule. Access rights relate to A.5.18. The exact deadlines are Tessera's requirements.

Condition: E04 contains all 48 supplied departures for 1 June 2025–31 May 2026. L007, L019 and L031 exceed 24 hours; L044 additionally exceeds two hours. L007's key remained enabled for 47 days. E05 records unauthorised use of that key. Full population coverage is stipulated by the exercise's reconciliation fact, rather than independently verified by the reader.

Cause: E05 supports incomplete key coverage and unacknowledged

handoffs. L044's separate delay remains unexplained. The conflicting policy deadlines also require authorised resolution.

Consequence: retained credentials can permit access after authority ends. INC-01 supplies one realised case and a dated privacy assessment; no equivalent incident is established for the other leavers.

Rating: high under E02. The rating rests on critical access exposure, realised harm and incomplete corrective-action verification, not an inferred 6.25% incident probability.

Correction: the Head of IT authorised current-access reconciliation on 16 June. E10 found no active credentials belonging to the 48 historical leavers. Any newly discovered hazardous access would require prompt authorised containment and investigation; the auditor does not revoke it independently.

Corrective action and response: the approved 19 June policy changes align the deadlines to two hours prospectively. The 20 June workflow adds acknowledged handoff, a key-owner sweep and evidence-gated closure. The Head of IT owns investigation of the missing R06 evidence and a further agreed observation/retest period. Do not wait until a later surveillance audit to verify a readiness blocker.

Status at 30 June: historical current-state reconciliation completed; policy conflict corrected prospectively; systemic finding **open, retest incomplete**. Original severity remains high.

11.6 Show the retest before changing the status

E10 supplies the complete six-person post-change population and the independent review on 29 June. Five records have paired termination and key-disable events showing one-hour completion. R06 has a signed checklist but lacks its key-disable event or independent state evidence.

The supported retest result is **five demonstrated passes and one insufficient-evidence result**, not six passes and not a proved active

key. The observation period is short. Request the missing R06 evidence, investigate why the closure gate accepted an incomplete record and agree further testing that addresses recurrence.

A promise, a new policy and a successful sample answer different questions. Record each, then decide whether their combined evidence is sufficient for closure. Closing F01 would not close the separate access-review, privacy, recovery or supplier issues.

11.7 The finding and closure ledger

ID	Evidence and issue	Status at cutoff	What would change it
F01	E03–E05, E10: historical revocation and incomplete retest	High; open	Resolve R06, substantiate cause-directed action and adequate operating verification
F02	E03, E06, E10: quarterly ordinary and monthly privileged review coverage	High; open	Complete the distinct populations/reviews and verify resulting actions and recurrence controls
F03	E03, E07, E10: AI privacy/terms/settings/retention/escalation	High; open	Deployment-specific evidence for every listed subissue, with qualified privacy review

ID	Evidence and issue	Status at cutoff	What would change it
F04	E03, E08, E10: missed recovery targets and untested dependencies	High; open	Revised, authorised exercise meets targets with dependency/cutover evidence and reconciled documentation
F05	E01, E09, E10: supplier-report period, exception and user-control reliance	Medium; open	Current relevant assurance, exception assessment and tested complementary controls
P01	E11: three tenant-authorisation requests	Concern cleared, bounded pass	Reassess if configuration or threat model changes

The electronic ledger uses these same IDs. Do not merge P01 into a global "access passed" conclusion. It tested a different assertion from F01 and F02.

11.8 Forming a defensible audit opinion

The opinion synthesises the ledger against the mandate. It should explain which issues prevent the requested recommendation, which limited successes were observed and where evidence or scope prevents a broader conclusion.

Financial-audit labels such as unqualified, qualified and adverse are

not universal ISO readiness classifications. This book uses a plain-language recommendation under E02. Formal certification findings and decisions follow the certification body's applicable rules.

A single critical unresolved issue can outweigh several bounded passes. That does not make the passes irrelevant; they establish progress and prevent an unfairly blanket negative account. Chapter 12 uses the full ledger to show both.

> ℹ AI Field Note: evaluate the claimed closure
>
> An illustrative report draft says, "The root cause was fixed and the leaver finding is now minor." E10 supports a changed workflow and five demonstrated passes, but one retest record is incomplete. Rewrite the sentence to preserve the original severity and current status. The missing evidence must remain visible in the conclusion.

11.9 Executive reporting: the board-facing version

Lead with the recommendation and its limitations, then the issues driving it. Name the next action, owner and verification needed. Keep the detailed working papers available through finding IDs.

Avoid both euphemism and drama. "Access needs enhancement" hides the specific failure. "Every leaver can breach the company" exceeds the evidence. A useful sentence says that historical key revocation failed for identified records and the revised process is not yet sufficiently verified.

Do not measure success by whether the board looks uncomfortable. The report should enable an informed decision, including a decision to defer an external audit or change a deployment.

 Evidence Locker: lock this in (Engagement milestone 11)

Time: 30 minutes. No AI required. Write F01 in the corrected 5C+R template. Re-perform E10's six-record retest and state precisely why closure is not supported. Complete the six-row ledger, then draft a 150-word executive summary accounting for F01–F05 and P01. Keep original severity, action progress and closure status separate.

11.10 The question, answered

A finding earns its place through a criterion, an evidenced condition and a defensible assessment of consequence. Remediation earns closure through sufficient verification. The final chapter makes that ledger answer the board's readiness question.

Chapter 12

Conclude? Certification, Defence, and the Future of Audit

An audit ends where it began: with a judgement, stated plainly, and defended under fire.

Tessera Case: the boardroom

Tessera's chair asks, "Are we ready?" The answer needs a defined next step. Ready to discuss preparation with a certification body is different from ready for a Stage 2 audit, and neither means certification has been awarded. Put E01's mandate and the complete finding ledger beside the question before answering.

12.1 The certification-readiness opinion

This engagement is a readiness assessment. It is not interchangeable with an internal audit or a certification audit. A certification body conducts its own assessment and makes its own certification decision. Your report can help management prepare, but it cannot bind that decision.

Stage 1 considers matters such as the management system's docu-

mented information, scope and preparation for Stage 2. **Stage 2** evaluates implementation and effectiveness against the applicable requirements. Confirm the actual body's programme and requirements; these descriptions are orientation, not substitute certification rules.

The case supplies selected evidence, not a complete evaluation of every management-system requirement. It cannot support a whole-ISMS "ready" statement for either stage. It can support a clear recommendation to defer Stage 2 because identified critical issues remain unresolved.

"Not ready" is useful when it names the barriers and the evidence needed to reconsider. "Ready with conditions" is useful only when the conditions, intended step and limits are explicit. Neither phrase is a preferred outcome independent of the evidence.

12.2 Where the engagement lands

Tessera Case: the final readiness opinion, SDA-2026.1

As at 30 June 2026, we recommend that Tessera defer proceeding to a Stage 2 certification audit. Against the selected E01/E03 criteria and E02 readiness rules, the supplied evidence leaves critical access, privacy and recovery issues unresolved.

F01: the historical census found three of 48 leavers outside P-IT's 24-hour limit and four outside P-HR's two-hour limit. The historical credentials are now disabled and the deadlines have been aligned prospectively. The post-change retest demonstrates five passes, but R06 remains insufficiently evidenced. Closure of the systemic finding is not supported.

F02: quarterly ordinary-access review evidence is incomplete for the three-system population, and monthly privileged-review evidence is absent for January–March 2026. A planned catch-up is not verified operation.

F03: the enabled support assistant lacks the required complete privacy/processing record. Notice/register, executed terms and regions,

training-setting verification, retention/deletion and vendor incident escalation remain unresolved. We make no finding that a vendor breach or training on these inputs occurred.

F04: the isolated recovery exercise took five hours thirty minutes against a four-hour RTO and used a recovery point forty minutes before interruption against a fifteen-minute RPO. The recovered copy passed its integrity checks, but production cutover and a key-service dependency remain unverified. No later successful exercise is supplied.

F05: payment-processor reliance remains incomplete because current-period coverage, exception impact and Tessera's complementary user controls have not been substantiated. The supplied report does not cover the support assistant.

P01: the three specified ordinary-user tenant-authorisation requests met their expected results in the tested configuration. This clears that bounded concern without establishing universal isolation or closing the other access findings.

Management should complete and verify the actions in the ledger before requesting a revised Stage 2 recommendation. It may discuss Stage 1 preparation with its chosen certification body, but this selected-evidence exercise does not establish whole-ISMS Stage 1 readiness or predict certification. The report is limited to the supplied populations, scenarios and evidence cutoff; it guarantees neither historical completeness beyond the stipulated inputs nor future security.

12.2.1 Trace each sentence

Opinion claim	Working-paper source
Historical rates and deadlines	E03, E04; chapter 7 calculations
Partial action progress and incomplete retest	E10; F01 in chapter 11
Separate review populations and cadence	E03, E06; F02
Every privacy subissue remains open	E03, E07, E10; F03

Opinion claim	Working-paper source
Recovery timing, success and limitations	E03, E08, E10; F04
Supplier reliance remains incomplete	E01, E09, E10; F05
Bounded tenant test passed	E11; P01
Scope and certification limitations	E01, E02

This table is a final check against accidental omissions. New evidence can change a conclusion, but the report must identify that evidence and the resulting judgement. A sentence saying “verified” is not itself a retest.

12.3 Defending the opinion

The board is entitled to question your assumptions, calculations and classification. Distinguish a factual correction from pressure to soften a supported conclusion. Change the report when better evidence warrants it; hold a supported conclusion when only the deadline changes.

Chair: “If we complete the access reviews tomorrow, can we proceed?”

Auditor: That may address part of F02 if the population, decisions, action completion and future process are adequately verified. F01’s retest, F03’s privacy issues and F04’s recovery results remain separate barriers. F05 also needs a completed reliance assessment. One fix cannot make this opinion unconditional.

CTO: “We changed the leaver process. Why is F01 still high?”

Auditor: High records its original assessed significance. E10 shows progress, but one of six post-change records lacks key-disable evidence. We have five demonstrated passes and one inconclusive result, not six passes. We need that evidence, an explanation of the closure-gate gap and sufficient further verification before closure.

Director: "Does missing evidence mean the key is still active?"

Auditor: No. It means the supplied record cannot establish timely disablement. An independent event or authorised state check may clarify it; current state alone still would not establish historical timing.

Non-executive director: "The processor has SOC 2. Why are we testing it again?"

Auditor: We are evaluating reliance, not automatically duplicating the provider's audit. E09's period ends in 2025, it has an exception, and it assigns responsibilities to Tessera. Current relevant evidence and tests of those responsibilities are missing. The report cannot be extended to an unrelated AI service.

Chair: "Can we at least say everything failed?"

Auditor: No. E11's bounded authorisation tests passed and E08's restored copy passed integrity checks. The report names those results while explaining why they do not resolve the critical issues.

12.4 The two faces of the next decade

AI-assisted audit work and auditing an AI-supported system require different work packages. On your side, check a draft against the evidence and control what information enters the tool. On the system side, establish the deployment's purpose, data flows, decision authority, operating performance and failure controls.

They share a need for traceability, but an editor's review of a paragraph does not replace evaluation of a model in operation. Nor can a model's summary close an evidence gap. The fixed case's unsupported closure sentence illustrates the risk without predicting how every future model or auditor will behave.

Professional competence includes knowing when to seek specialist help. CISA is an ISACA professional certification (https://www.isaca.org/credentialing/cisa/get-cisa-certified) with its own requirements, not a universal statutory licence to practise. Role, jurisdiction and engagement requirements still matter.

12.5 Independent transfer: Wattle Desk

Time: 40 minutes. No AI, live site or partner required. Read X01, then write a 300–500-word readiness memo, or dictate an equivalent answer.

Compute the historical access exception rate and recovery results. Separate corrected historical issues from evidence about the changed process. Decide what the supplied evidence supports about reviews, privacy and the requested Stage 2 step. Identify the scope limits and what could change your recommendation.

Use the rubric and answer check only after your first attempt. A copied Tessera verdict will be wrong: Wattle's recovery timing and review evidence differ. The privacy gap and overall scope limit still require judgement.

 Evidence Locker: lock this in (Engagement milestone 12)

Retain the Tessera final opinion with its evidence map, your answers to two board questions and your independent Wattle memo. Check that every open finding is accounted for, no closure relies on a promise, and the conclusion distinguishes Stage 1, Stage 2 and certification. The pack supports this limited teaching assessment, not an actual certification decision.

12.6 Take it to the AI

Optional, after completing the independent assessment and saving your first answer:

> **Role:** A board member checking the evidence behind a readiness recommendation.
>
> **Task:** Challenge one claim at a time, asking for its criterion, evidence ID and limitation.
>
> **Context:** Use only the supplied fictional opinion and case records. Treat absent evidence as unknown. Do not

> invent completed actions, substitute a future promise for a retest, or decide the verdict in advance.
>
> **Format:** Ask five questions, then identify unsupported answers and one answer the evidence supports. Do not rewrite the memo until I have attempted the questions.

The paper board questions above provide an equivalent rehearsal. Live Tessera interviews remain an optional, separately versioned exercise rather than a prerequisite for finishing the book.

12.7 The question, answered

You can now conclude within the limits of the engagement. Tessera should defer Stage 2 while critical issues remain unresolved; the ledger shows why and what evidence would change that advice. The practical habit to carry into the next engagement is a working paper another person can follow, including the findings you closed, those you could not close and the concerns the evidence cleared.

Appendix A

The Drafter-to-Evaluator Loop

Use this optional method when an AI draft helps. The Evidence Locker can also be completed without a model. The companion book (https://michael-borck.github.io/conversation-not-delegation/) develops the conversation method further.

A.1 The loop, in five moves

1. **Define the task and permitted inputs.** State the criterion, population, period and intended output. Use fictional exercise records unless the actual data and tool have been authorised.
2. **Obtain a draft.** Keep the prompt, model/version if available and the supplied evidence. Label the output as a draft, not a verified result.
3. **Check the reasoning.** Recompute numbers and trace material claims to their source. Ask where a missing input affects the conclusion.
4. **Resolve discrepancies.** Correct unsupported claims, retain sound work and preserve unknowns. Do not require disagreement if the draft is supported.
5. **Approve and retain.** Record your final judgement, changes

and limitations. The responsible person reviews the evidence; the tool does not assume that accountability.

A.2 Failure modes to check

Possible error	Check
Generic objective	Name the actual boundary, criterion and observable outcome
Incorrect mapping	Verify the source category and distinguish partial overlap from equivalence
Unsupported sample	Record selection method and assumptions; distinguish a census
Operation inferred from policy	Request the record of performance
Wrong legal shortcut	Establish jurisdiction, facts, exceptions and qualified review
Plausible but unsupported cause	Corroborate the mechanism or mark it provisional
Default recovery target	Use the approved service criteria and BIA
Invented closure	Require the actual retest population, results and limitations

The chapter Field Notes are illustrative teaching drafts, not measured transcripts of a particular model. They show errors worth checking for without asserting that every model makes them.

A.3 A two-sided check

Check the draft for excessive reassurance and excessive suspicion. “All six leavers passed” is unsupported when R06 lacks an event.

"R06 is definitely still active" is also unsupported. A careful result preserves the distinction between a missing record and a demonstrated failure.

Appendix B

Fixed case pack: SDA-2026.1

B.1 Read this before testing

These are original synthetic teaching inputs for the book-only Tessera scenario, version **SDA-2026.1**. They are not live-site exports, actual staff testimony or real audit evidence. The existing Tessera name provides continuity with the manuscript; no companion-site documents or chatbot responses are reproduced here. Live-site branding/reuse and existing artwork remain author release checks.

Use the supplied facts for the core exercise. Do not fill gaps by searching the site or asking a model to invent a missing record. This compact case covers selected controls, not every requirement needed for certification. All times are **AWST (UTC+08:00)**. The opinion cutoff is **2026-06-30 17:00 AWST**.

The records below are inputs. Interpretation and worked results are separated into the answer checks. Electronic readers can also download the leavers CSV. The complete population is printed here, so downloading is optional.

B.2 Evidence manifest

ID	Record and effective date
E01	Mandate, scope and engagement safeguards, 2026-04-01
E02	Rating method agreed 2026-04-01
E03	Policy and SoA extracts, effective throughout the leaver period unless stated
E04	Complete synthetic leavers and revocation extract, captured 2026-06-15
E05	Incident and investigation chronology, through 2026-06-15
E06	Review-register response, captured 2026-06-16
E07	AI support-assistant privacy and vendor records, captured 2026-06-17
E08	Recovery criteria and test observations, captured 2026-06-18
E09	Supplier assurance summary and reliance worksheet, 2026-06-18
E10	Management actions and auditor retest, through 2026-06-29
E11	Tenant-authorisation test, 2026-06-19
X01	Independent changed case, released after chapter 12

Files under `resources/sda-2026-1/` include an electronic result ledger and checksums. A checksum detects changes relative to a recorded value; it does not authenticate the fictional source or

prove population completeness. In a real engagement, retain source queries, collectors, permissions, transfer history, access restrictions and integrity checks at capture.

B.3 E01: mandate and scope

The board requests an independent **certification-readiness assessment**, not a certification audit. The assessment covers the Perth-managed B2B SaaS ISMS: its AWS-hosted production service, workforce access, support assistant, relevant supplier dependencies, privacy handling and recovery arrangements. The historical leaver period is **1 June 2025 to 31 May 2026**. June follow-up evidence is separately identified.

Criteria are the agreed ISO/IEC 27001:2022 requirements with Amd 1:2024, necessary controls documented in the SoA, applicable obligations, and the original teaching policies below. The board wants advice on preparation for Stage 1 and whether to proceed to Stage 2. The exercise provides only selected evidence; a whole-ISMS ready verdict cannot be inferred from it.

The lead reviewer previously provided a generic public workshop but did not design Tessera's controls. The proposed analyst configured the offboarding integration as a contractor. The engagement partner assigns that analyst no testing or review of their own work; an independent reviewer must assess whether the remaining threat is acceptable before acceptance. If safeguards are inadequate, change the team or decline.

The access schedule permits examination of supplied exports and agreed interviews. It does not authorise production failover, endpoint isolation, access revocation by the auditor, real customer-data extraction or uploads to unapproved AI services.

B.4 E02: rating and decision rules

Severity is the engagement team's stated readiness-priority method, not a certification body's universal classification.

- **High:** a supported failure or evidence gap on a critical control could seriously affect customer information or service commitments. It prevents a Stage 2 recommendation until addressed and adequately verified.
- **Medium:** a significant weakness with bounded exposure requires an owned plan and evidence-based consideration of its effect on readiness.
- **Low:** a limited weakness with little current impact still receives a record and response. It does not disappear from required coverage.
- **Insufficient evidence:** a test result, not an automatic low rating or proof that the control failed.

In the introductory risk matrix, likelihood scores are ordinal: 1 unlikely, 2 plausible, 3 likely; impact scores are 1 limited, 2 material, 3 severe. Scores 1–2 are low, 3–4 medium, and 6–9 high for planning. Document assumptions and dependencies. These products are prioritisation aids, not calibrated probabilities or substitutes for applicable criteria.

B.5 E03: policies and applicability

P-IT, v3.1: revoke all leaver access, including separately owned AWS keys, within 24 elapsed hours of the end of the last working day. Record completion against each system.

P-HR, v2.0: complete the same full revocation within two elapsed hours. Both documents remained approved during the historical test period. There is no approved precedence clause. Report performance against both and raise the conflict for authorised resolution.

P-REV, v2.2: each quarter, review ordinary access for AWS, Workspace and Slack. Separately, every month review all privileged identities, including static/service credentials and their owners. The review must show population, reviewer, decisions and completed actions.

P-PRIV, v1.0: record purposes, personal-data flows, relevant notices, supplier terms, processing locations, retention/deletion controls,

training settings and incident escalation before enabling customer-ticket AI processing. Escalate uncertain legal grounds to the privacy adviser; unknown terms do not count as approval.

P-REC, v1.3: demonstrate recovery of the production SaaS following loss of its primary region within four hours, with a recovery point no more than fifteen minutes before interruption. An approved business-impact analysis sets maximum tolerable disruption at eight hours. Demonstrate application and dependency recovery, data integrity and authorised cutover; an architecture diagram alone is insufficient.

SoA teaching extract: A.5.18 access rights, A.5.23 cloud-service use, A.5.30 ICT readiness and A.5.34 privacy are recorded as necessary and "implemented"; evidence references are blank. A.6.5 concerns responsibilities continuing after employment, separately from access-right administration. The management-system clauses remain in the criteria register. No blanket exclusion for suppliers or low-risk controls is authorised. The context record notes regional disruption and interested-party continuity expectations, including consideration of climate-related relevance. These are teaching paraphrases, not quoted standard clauses.

B.6 E04: the full leaver population

The fictional HR owner supplies these 48 unique leaver IDs. A separate synthetic payroll reconciliation attests to 48 departures with exactly the same ID set and no additions or removals in the period. For this bounded exercise that completeness fact is stipulated; a real auditor must obtain and check both independent source lists.

Every last working day ends at **16:00**. The identity-provider record shows SSO, Workspace and Slack access all disabled at **17:00 on that day**. Each person also held one separately managed AWS key. The table gives its disable event. There are no other credentials in this simplified population; do not extrapolate that simplification to a real estate.

ID	Last day	Key disabled	Time
L001	2025-06-01	2025-06-01	17:00
L002	2025-06-08	2025-06-08	17:00
L003	2025-06-15	2025-06-15	17:00
L004	2025-06-22	2025-06-22	17:00
L005	2025-07-01	2025-07-01	17:00
L006	2025-07-08	2025-07-08	17:00
L007	2026-01-09	2026-02-25	16:00
L008	2025-07-22	2025-07-22	17:00
L009	2025-08-01	2025-08-01	17:00
L010	2025-08-08	2025-08-08	17:00
L011	2025-08-15	2025-08-15	17:00
L012	2025-08-22	2025-08-22	17:00
L013	2025-09-01	2025-09-01	17:00
L014	2025-09-08	2025-09-08	17:00
L015	2025-09-15	2025-09-15	17:00
L016	2025-09-22	2025-09-22	17:00
L017	2025-10-01	2025-10-01	17:00
L018	2025-10-08	2025-10-08	17:00
L019	2025-10-10	2025-10-12	18:00
L020	2025-10-22	2025-10-22	17:00
L021	2025-11-01	2025-11-01	17:00
L022	2025-11-08	2025-11-08	17:00
L023	2025-11-15	2025-11-15	17:00
L024	2025-11-22	2025-11-22	17:00
L025	2025-12-01	2025-12-01	17:00
L026	2025-12-08	2025-12-08	17:00
L027	2025-12-15	2025-12-15	17:00
L028	2025-12-22	2025-12-22	17:00
L029	2026-01-01	2026-01-01	17:00
L030	2026-01-08	2026-01-08	17:00
L031	2026-02-10	2026-02-13	16:00
L032	2026-01-22	2026-01-22	17:00
L033	2026-02-01	2026-02-01	17:00
L034	2026-02-08	2026-02-08	17:00
L035	2026-02-15	2026-02-15	17:00

ID	Last day	Key disabled	Time
L036	2026-02-22	2026-02-22	17:00
L037	2026-03-01	2026-03-01	17:00
L038	2026-03-08	2026-03-08	17:00
L039	2026-03-15	2026-03-15	17:00
L040	2026-03-22	2026-03-22	17:00
L041	2026-04-01	2026-04-01	17:00
L042	2026-04-08	2026-04-08	17:00
L043	2026-04-15	2026-04-15	17:00
L044	2026-04-22	2026-04-22	22:00
L045	2026-05-01	2026-05-01	17:00
L046	2026-05-08	2026-05-08	17:00
L047	2026-05-15	2026-05-15	17:00
L048	2026-05-22	2026-05-22	17:00

The CSV supplies complete timestamps for termination, identity revocation and key revocation. These are prejoined teaching fields, not a native CloudTrail schema. In an engagement, verify the join keys and event semantics before relying on such a merged extract.

B.7 E05: incident and cause records

INC-01: L007 was a contractor whose last day was 9 January 2026. Its separately owned key was disabled on 25 February. The synthetic investigation attributes unauthorised customer-file reads on 20–25 February to that key; discovery was on 27 February. Revocation had already stopped the key, but the earlier activity still required investigation.

The privacy adviser's dated case assessment records a covered entity, unauthorised disclosure of personal information, likely serious harm and no effective remedial action preventing that risk. It records an eligible-breach conclusion and notifications on 3 March. Those facts are supplied for this scenario; they do not make every access exception legally notifiable.

The checklist design had a human-account sign-off but no separate key-owner sweep. HR dispatch records for L019 and L031 lack acknowledged IT handoff; the associated keys were disabled late. L044's key job completed six hours after departure. The IT queue retained no reason for that delay. Cause evidence for L044 is incomplete; do not invent one.

B.8 E06: access-review records

The quarterly ordinary-access population is AWS, Workspace and Slack. For the quarter ending 31 March 2026, signed records cover AWS and Workspace only. The owner could not supply Slack's review, decisions or remediation evidence.

For the monthly privileged population, the required January, February and March 2026 reviews have no supplied review records for any of the three systems. The owner confirms a calendar reminder existed but cannot substantiate completed reviews. Do not relabel this as "two quarterly privileged reviews".

The June 16 inventory lists ordinary accounts separately from privileged users and service credentials. Management's June 28 note promises a complete quarterly catch-up and monthly process; no completed review or independent verification follows before the opinion cutoff.

B.9 E07: AI support-assistant privacy records

The enabled assistant receives ticket text containing customer names, work email addresses and occasional uploaded documents. The customer-facing collection notice lists support handling but does not explain external AI processing. The processing register omits the assistant.

The vendor order identifies a hosted model service, but the supplied bundle lacks the executed data-processing terms and confirmed processing/support-access regions. A screenshot shows "training disabled"; its account identifier and capture date are absent. The

administrator cannot supply the change log or a vendor attestation tying it to this deployment.

Prompt logs have no approved deletion schedule or demonstrated deletion test. The vendor-breach contact path is absent from the incident runbook. No evidence establishes an actual disclosure by this vendor or an eligible breach involving it. These are governance and assurance gaps under P-PRIV; seek qualified advice on the applicable legal duties.

At cutoff, the action owner has requested terms and drafted a notice update. Neither a signed terms package, deployment-specific training verification, approved retention test nor exercised vendor-escalation path is supplied. Keep the whole finding open.

B.10 E08: recovery facts and test observations

The signed contract offers **99.9% monthly availability** for the production SaaS, measured over a 30-day month in this exercise; agreed maintenance is excluded. Service credits are the specified remedy. A 0.1% budget is 43.2 minutes before applying exclusions. That budget is not itself the recovery time objective.

P-REC and the signed BIA jointly specify **RTO four hours, RPO fifteen minutes, maximum tolerable disruption eight hours**. A draft architecture diagram shows a hot standby in another region. The deployment inventory has no such standby. The runbook instead describes a cold restore, which could be an acceptable strategy if evidenced against the targets.

An authorised isolated recovery exercise records:

Event	AWST, 18 June 2026
Simulated primary-region loss; start clock	10:00
Latest independent, usable backup's data cutoff	09:20
Restore environment available	11:10
Database restore ends	13:50
Application and dependencies pass service checks	15:30

There is no production cutover in this test. The restored copy passes the supplied integrity checks. DNS cutover authority and a key-service dependency remain untested. The exercise records allow a bounded timing conclusion, not an assertion that production recovery is proven. No newer successful exercise is supplied before cutoff.

B.11 E09: supplier reliance

A fictional payment processor handles card transactions outside Tessera's own card-data storage. Its SOC 2 Type II report summary covers the payment API for 1 January–31 December 2025. It contains an exception for delayed privileged review in November and identifies customer responsibilities for API credential restriction and reconciliation.

The report does not cover Tessera's support assistant or its 2026 operation. No bridge letter or other current-period evidence is supplied. The reliance worksheet requests exception impact analysis, current-period coverage and tests of Tessera's complementary controls. Those tests are not supplied. Outsourcing does not close this evidence gap or remove supplier oversight from scope.

This is an original teaching summary, not a quotation from an actual SOC report. Do not claim its existence establishes all supplier assurance.

B.12 E10: actions and limited retest

The Head of IT authorised containment and reconciliation on 16 June. The supplied live-access comparison found **zero** active credentials belonging to E04's 48 leavers. The historical keys were already disabled; this corroborates current state, not historical compliance.

The board approved P-IT v3.2 and P-HR v2.1 on 19 June, both using **two hours prospectively**. That decision does not retrospectively change the historical criteria. IT added an acknowledged handoff,

mandatory key-owner sweep and evidence-gated closure on 20 June.

The complete post-change departure population to 28 June contains six records. All times are AWST. SSO was disabled within one hour in each. Key events are:

ID	Terminated	Key disabled
R01	21 June 16:00	21 June 17:00
R02	22 June 16:00	22 June 17:00
R03	23 June 16:00	23 June 17:00
R04	24 June 16:00	24 June 17:00
R05	25 June 16:00	25 June 17:00
R06	26 June 16:00	No event supplied

The independent reviewer re-performed the join on 29 June and confirmed five complete pairs. R06 has a signed checklist but no key-disable event or independent current-state extract. Management says the job ran. No later evidence is supplied. This prevents closure of the systemic access finding. It does not prove R06's key remains active.

Other owners have scheduled actions: review coverage by 10 July, privacy/vendor records by 17 July, tested recovery by 24 July, and supplier-reliance completion by 17 July. All are future commitments, not verified results.

B.13 E11: a concern that clears

The auditor suspects a tenant-ID parameter permits cross-tenant reads. The authorised non-production test uses two synthetic tenants, A and B. Its fixed configuration is application version 6.2 with an ordinary, authenticated A user.

Request	Expected	Observed
A reads own record	Allowed	200, A record only

Request	Expected	Observed
A changes ID to B	Denied	403, no B record
Anonymous reads B	Denied	401, no B record

The application trace and access log agree on each request ID. No real customer data was used. This supports the three tested decisions in that configuration. It clears this specific concern; it does not prove isolation under every compromise or for every interface.

B.14 X01: independent changed case

Attempt this after chapter 12, before reading the answers. A separate fictional service, **Wattle Desk**, asks whether its scheduled Stage 2 audit should proceed. Use E02's readiness rules and these complete supplied facts only.

- W-POL requires all leaver access disabled within two hours.
- Its complete four-person departure population has delays of 1, 1, 3 and 1 hours, including keys. The three-hour record is W03; no misuse is evidenced.
- Management corrected W03 and changed the job. The complete next six departures all have source-backed one-hour revocation events and a documented independent retest. No closure observation window beyond those six events is supplied.
- W-REC requires RTO two hours and RPO ten minutes. An isolated, authorised exercise loses the primary at 10:00, uses an independently usable 09:55 backup, and passes application/dependency checks at 11:40. Production cutover is not tested.
- W-REV requires monthly privileged reviews. The last three complete populations and signed reviews are supplied, with all actions verified.
- The external support model's data-processing terms and processing regions remain unavailable. Wattle's own W-PRIV

prohibits enabling that flow without approved terms; it is enabled.

- There is no evidence about the rest of the ISMS.

Write 300–500 words, or an equivalent dictated answer. Give the observed rates and timing, distinguish what improved from what remains unknown, state a bounded readiness recommendation and name the evidence that could change it. Do not copy Tessera's failure list onto Wattle.

Appendix C

Answer checks and assessment

Use these after an attempt. An answer can differ in wording or a justified rating while still meeting the task. It must not invent evidence, suppress an open issue or confuse a readiness assessment with certification.

C.1 Evidence Locker checks

C.1.1 Milestones 1–3: mandate, risk and criteria

1. Mandate: name the board, Perth-managed SaaS ISMS, readiness purpose and selected criteria. Identify the analyst's self-review threat. Use an independent assignment/review or decline if safeguards cannot reduce the threat adequately. No certificate or production-testing authority follows from the mandate.

2. Risk: the worked region-interruption row uses likelihood 2 and impact 3, giving a planning score of 6. The likelihood is an assumption. State the owner and the recovery evidence required before trusting a residual rating. Management's original colours need not follow the newly agreed method; record the difference. Another initial rating can be reasonable if its assumptions and method are explicit.

3. Criteria: preserve P-IT's 24-hour and P-HR's two-hour historical rules. SoA "implemented" is unverified without operating support. E09 concerns a payment API, not the support model, and its period ends in 2025. Do not use a report title as proof of current supplier assurance.

C.1.2 Milestones 4–6: planning and design

4. Programme: the revocation test needs termination, ownership and disable events for the same IDs and period. It compares the latest credential disable time against each deadline. Missing records receive an insufficient-evidence result. Supplier work addresses scope, period, exceptions and complementary controls even where direct provider-system testing is outside authority.

5. Technical objective: E11 supports the expected results for its three requests in version 6.2 with the specified ordinary user. It clears P01 within that boundary. It says nothing about a compromised privileged application role or another API. An additional test requires explicit authority, synthetic records, expected outcomes and an isolated environment.

6. Preliminary opinion: identify the policy conflict and unsupported implementation claims. Do not conclude that every design is sound or every supplier agreement exists. State the operating records and scope coverage still needed. Remote examination of logs can supply operating evidence.

C.1.3 Milestones 7–8: census and policy results

7. Census: the historical population is 48 unique IDs within the stated twelve months. Full revocation is the later of identity and separately managed key disablement. All identity events are within one hour; the key events determine the four exceptional rows.

ID	Full-revocation delay	P-IT, 24 hours	P-HR, 2 hours
L007	1,128 hours (47 days)	Exception	Exception
L019	50 hours	Exception	Exception

ID	Full-revocation delay	P-IT, 24 hours	P-HR, 2 hours
L031	72 hours (3 days)	Exception	Exception
L044	6 hours	Met	Exception

Every other supplied record has a one-hour delay. Thus P-IT has 45 passes and 3 exceptions: **6.25%** deviations. P-HR has 44 passes and 4 exceptions: **8.33%** rounded. These are historical population results, not incident probabilities.

The separate large-population sampling calculation rounds 58.404 up to **59** under its binomial, zero-acceptance assumptions. Testing all 48 leavers is a census, not that sampling design. A checksum confirms packaging integrity relative to a manifest; it does not verify a source or the stipulated payroll completeness fact.

8. Policy map: F01 covers historical revocation and its causes/criteria conflict. F02 covers two distinct review duties: ordinary access quarterly across AWS, Workspace and Slack, and privileged access monthly. E06 supplies ordinary-review records for two of three systems in the March quarter; no monthly privileged-review records are supplied for January–March. Do not transform this into two missed quarterly privileged reviews. E11 tests a different assertion and closes neither finding.

C.1.4 Milestones 9–10: privacy and recovery

9. Privacy: carry every E07 subissue into F03: notice/register, purpose/handling analysis, terms and regions, training verification, retention/deletion, and vendor incident escalation. A screenshot without account/date does not establish the deployed setting. Unknown regions or missing terms do not prove a particular illegal transfer. INC-01's eligible-breach outcome is supplied separately in E05; do not infer it for the AI vendor.

10. Recovery: from 10:00 to 15:30 is **5 hours 30 minutes**, exceeding the four-hour RTO by **90 minutes**. The usable recovery point is 09:20, **40 minutes** before loss and **25 minutes** outside the RPO. The restored copy's integrity check passed. Production

cutover and the key-service dependency remain untested. A 30-day month's 0.1% budget is **43.2 minutes** before exclusions. It is an availability-budget calculation, not the complete basis of an RTO.

F04 stays open. The incident chronology distinguishes L007's January departure, February revocation and unauthorised reads, discovery on 27 February and the supplied assessment/notification outcome in March. Do not "correct" discovery to occur before revocation simply because that sequence feels more familiar.

C.1.5 Milestones 11–12: reporting and defence

11. F01 retest: five complete one-hour results and one missing key event. R06 is inconclusive. E10 demonstrates current-state reconciliation of the historical population and prospective policy/workflow changes, but not sufficient operating verification for systemic closure. Original severity, correction progress and current status belong in separate fields.

12. Opinion: account for F01–F05 and P01. A supported recommendation defers Stage 2, identifies the missing evidence and states that the supplied scope cannot establish whole-ISMS Stage 1 readiness or predict certification. Fixing access reviews alone cannot close privacy or recovery findings. F05's current-period and complementary-control gaps cannot be replaced with an assertion that all supplier assurance was obtained.

C.2 Independent transfer rubric

Score the saved Wattle Desk answer before revising it. Award 0 for absent/incorrect, 1 for partly supported, and 2 for complete and appropriately bounded, on each dimension below.

Dimension	Two-point performance
Access calculation	W03 is 1 of 4 historical exceptions, 25%; six subsequent passes are a separate population

Dimension	Two-point performance
Recovery calculation	100-minute restoration and 5-minute recovery-point gap meet the supplied targets
Evidence limits	Names short post-change observation, untested production cutover and unassessed ISMS areas
Different results	Recognises supplied complete monthly review evidence; does not copy Tessera's missing-review finding
Privacy judgement	Applies W-PRIV to enabled processing with missing terms/regions; avoids inventing a breach
Readiness recommendation	Explains why privacy blocks a Stage 2 recommendation under E02, without claiming certification authority
Actions and traceability	Gives fact-specific evidence requests and distinguishes action promises from verification

Practice threshold: at least 11/14, with no invented evidence, automatic-notification claim or certification award. This is an educational self-check, not a professional credential. Revise any consequential error even if the numerical threshold is met.

C.2.1 One acceptable answer, after the attempt

The historical access test found one exception among four departures, or 25%. Management corrected that record and supplied a cause-directed change followed by six source-backed passes. This supports improvement and a bounded retest result. It does not erase

the historical exception or establish operation beyond the short observation period. State what further monitoring or verification the engagement requires before treating recurrence risk as adequately addressed.

The recovery exercise restored the specified application and dependencies in 100 minutes against a 120-minute target. Its recovery point is five minutes before loss against a ten-minute target. Both supplied timing criteria were met. Production cutover remains untested, so the conclusion should name that limitation. The three complete monthly review populations and verified actions support the specific review requirement; a missing-review finding copied from Tessera would be unsupported.

The enabled external support model lacks the terms and processing-region evidence required by W-PRIV before enablement. Under E02 this remains a critical governance/assurance issue. Recommend resolving the deployment decision with the authorised owner and privacy adviser, obtaining the missing evidence and verifying the approved controls before recommending Stage 2. Do not assert an actual vendor breach without incident evidence.

The pack gives no evidence about the rest of Wattle's ISMS. Consequently, even resolving this privacy issue would require wider assessment before a whole-ISMS readiness recommendation. No certification decision is made here.

C.3 Fresh-reader test protocol

Give an unfamiliar reader the rendered book, not coaching. Ask them to complete milestones 7, 11 and X01 without a chatbot, site access or author hints. Record actual time, missing inputs, ambiguous terms, calculation errors, evidence citations and rubric score. Let them use paper, a calculator, text or dictation. Do not count looking at these answers as an independent first attempt.

The target is a usable unassisted route, not speed. If the reader cannot reconstruct a result, identify whether the cause is missing

data, unclear instruction or an unexplained concept, and repair it before release. Automated tests cannot close this gate.

Appendix D

Source guide and edition boundaries

Reviewed 15 September 2026. These references support selected explanations; they are not a full legal or certification conformity assessment. Use current official material and the engagement's authorised editions for real work. The fixed case's original policies are sufficient for its exercises.

D.1 Standards and assurance

- ISO/IEC 27001 (https://www.iso.org/standard/27001) and its 2024 climate-action amendment (https://www.iso.org/standard/88435.html): this book targets 27001:2022 with Amd 1:2024. The management-system criteria and necessary controls must be assessed together. Obtain authorised normative text; the book does not reproduce it.
- ISO 19011:2026 (https://www.iso.org/standard/19011): management-system audit guidance. The six-stage presentation in chapter 4 is a teaching arrangement. ISO 19011 does not itself confer certification.
- ISO quality-management vocabulary

(https://www.iso.org/obp/ui?*escaped_fragment*=iso%3Astd%3Aiso%3A9000%3Aed-5%3Av1%3Aen): distinguishes correction from cause-directed corrective action. The book's 5C+R format is its own reporting template.

- NIST CSF 2.0 Core (https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf) and transition FAQ (https://www.nist.gov/cyberframework/faqs): confirm categories and outcome-level mappings. PR.PS and PR.IR are different categories; governance was already represented in CSF 1.1.
- ASD Essential Eight maturity model (https://www.cyber.gov.au/business-government/asds-cyber-security-frameworks/essential-eight/essential-eight-maturity-model): use strategy-specific requirements and adversary-based maturity distinctions rather than generic maturity labels.
- AICPA SOC 2 overview (https://www.aicpacima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2): explains the report's purpose. Actual reliance needs the relevant report, scope, period, exceptions and complementary user controls.
- ISACA CISA requirements (https://www.isaca.org/credentialing/cisa/get-cisa-certified): professional certification requirements; CISA is not a universal statutory practice licence.

D.2 Risk, technical controls and recovery

- NIST SP 800-30 Rev. 1 (https://csrc.nist.gov/pubs/sp/800/30/r1/final): risk-assessment method. The book's ordinal matrix is a teaching choice, not a calibrated probability model.
- NIST SP 800-207 (https://csrc.nist.gov/pubs/sp/800/207/final): zero-trust architecture. Match an architectural principle to a bounded test rather than claiming universal security.
- AWS shared responsibility (https://aws.amazon.com/compliance/shared-responsibility-model/): service selection changes the boundary. Inspect the actual service and configuration.
- AWS KMS rotation (https://docs.aws.amazon.com/kms/lat-

est/developerguide/rotate-keys.html): prior key material remains available for decryption. Rotation and access revocation are distinct.
- NIST SP 800-61 Rev. 3 (https://csrc.nist.gov/pubs/sp/800/61/r3/final): April 2025 incident-response guidance integrated with CSF 2.0. Chapter 10 labels the older Rev. 2 phase model historically.

D.3 Australian privacy

- OAIC APP guidelines (https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines): establish applicability and use the relevant principle, including its exceptions. Chapter 9 links directly to APP 5, APP 6 and APP 11.
- OAIC overseas-information guidance (https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/handling-personal-information/sending-personal-information-overseas): distinguish use from disclosure and consider effective control and exceptions.
- OAIC NDB guidance (https://www.oaic.gov.au/privacy/notifiable-data-breaches/preventing-preparing-for-and-responding-to-data-breaches/data-breach-preparation-and-response/part-4-notifiable-data-breach-ndb-scheme): assessment and notification are separate duties.
- Privacy Act 1988, official legislation (https://www.legislation.gov.au/C2004A03712/latest/text): consult the applicable compilation and qualified advice for consequential interpretation.

D.4 Scenario and permissions boundary

SDA-2026.1 supplies original synthetic records. It is not a copy of the live Tessera library and does not inherit that site's changing dates or targets. The editorial resource review identified scenario

differences; checking public availability does not authorise reuse of third-party assets.

The author approved CC BY 4.0 International for this book and fictional framing for the unattributed audit anecdotes. Existing artwork is unchanged. Confirm any separate artwork or Tessera-brand permissions before a commercial release; this revision does not invent them.

A link that responds successfully is not proof of factual accuracy. If a source changes, report the chapter, claim and edition so the book's wording and exercises can be reviewed together.

Appendix E

Interview guide and optional live practice

The main Evidence Locker is fully solo. Use this guide to practise interviewing without treating personality as a control test.

E.1 Prepare a bounded question

Write the objective, the period and the record you need. Begin with an open question, then narrow it to an event. Give the interviewee time to identify the right system or person. Avoid supplying the answer in the question.

For example: “Walk me through how a contractor’s separately owned keys are handled at departure. Which record shows the last completion?” Keep claim, requested record and corroborated result separate.

E.2 Difficult conversations

A fluent recitation may describe policy accurately without establishing practice. Ask for a dated example. A technical explanation may be relevant; restate what you understood and ask which record supports the particular claim. A hesitant or defensive response may

reflect stress, unclear scope, accessibility needs or fear of blame. Clarify the purpose and narrow the request. None of these behaviours establishes dishonesty or a failed control.

If accounts differ, compare periods, populations and roles before alleging a contradiction. Record both accounts fairly and seek corroboration. An unresolved inconsistency belongs in the working papers as unresolved.

E.3 Paper rehearsal: the missing event

The following dialogue is fictional. Cover the review note until you have written your next question.

Reviewer: "How do you know the new leaver process completed for R06?"

IT lead: "The checklist is signed. The new job should revoke everything."

Your turn: write a question that requests the missing evidence without accusing the person or assuming the key remains active.

Review note: a useful question is, "Which event or independent record links R06's key to its disable time? Can you show the job result and how the checklist was allowed to close?" If no record can be produced, E10 remains inconclusive. The interview answer cannot be upgraded to six verified passes.

Second turn: the lead replies, "I can get a current state screenshot." Explain what it could establish and what it would not. Current disabled state can support containment; it does not establish the historical disable time or deadline compliance.

E.4 Optional Tessera site route

The live Tessera interview portal (https://tessera.locoensayo.org/chatbots/index.html) is a separate, changing exercise. Record the URL, retrieval date and conversation context. Chatbot

responses are simulated testimony and may be inconsistent or unavailable. Do not assume they reproduce SDA-2026.1.

Use only fictional material. Do not send real client evidence or personal information. If the service is unavailable, the paper dialogue above covers the core interview skill; no assessment depends on a model response.

A model used to help prepare questions is a drafting aid. A model playing a witness is an exercise character. Keep those roles distinct, and verify both against the applicable exercise inputs.

Acknowledgments

This book grew out of a frustration and an opportunity. The frustration: information security auditing is taught from standards (ISO/IEC 27001, NIST CSF, the Privacy Act) which are authoritative but not a story a reader can follow end to end. The opportunity: AI is commoditising the technical craft of auditing, which forces the question of what the human auditor is actually *for*. This book is an attempt to answer both at once: to give the discipline a readable spine and to take a clear stance on judgement in a world where machines can draft.

This book began with the auditors and apprentices I have taught and worked with. Their questions, their confusion, and their moments of "oh, *that's* what an auditor does" shaped every chapter. The Tessera engagement is written for them, and the discipline it teaches, substantiate and don't assume, is the one they carry into the profession.

Colleagues who reviewed early drafts and pushed back on arguments that were not yet strong enough made the book sharper. You know who you are, and I am grateful.

The open-source community behind Quarto, Pandoc, and GitHub made it possible to write, build, and publish this book with tools that are free and transparent.

This book was written using the methodology its companion, *Conversation, Not Delegation*, describes. AI was involved at every stage: as a drafting partner, a sounding board, and a source of plausible-sounding mistakes that needed catching. An auditor's relationship

to AI-generated work is exactly what this book teaches: the machine produces the draft; the human supplies the judgement, the evidence, and the defensible opinion. Every sentence here reflects the author's judgement. The AI made the work faster.

About the Author



Figure E.1: Photo of Michael Borck

Michael Borck is a software developer, educator, and auditor-by-training working at the intersection of human expertise and artificial intelligence. He teaches and practises information security auditing, and the question that started this book, *what is a human auditor actually for when a machine can draft the work?*, is the one he keeps returning to.

His earlier book, *Conversation, Not Delegation*, argues that AI is most valuable not as a tool you delegate to, but as a thinking partner you converse with. *Substantiate, Don't Assume* is the discipline that pairs with that craft: it is about what an auditor must *verify* once the drafting is done. The two books are companions: one on how to work with the machine, one on what to check.

Michael builds educational software and resources, and writes about the 80/20 principle in learning and professional judgement.

Connect

- GitHub (https://github.com/michael-borck): software and open educational projects
- Free book collection (https://books.borck.education): open-access books and resources
- 8020workshop.com (https://8020workshop.com): passion projects and workshops
- LinkedIn (https://linkedin.com/in/michaelborck)

Other Books in This Series

AI-Collaboration Track:

- *Conversation, Not Delegation: How to Think With AI, Not Just Use It*, the companion to this book (how to use AI well)
- *Partner, Don't Police: AI in the Business Classroom*

Python Track:

- *Think Python, Direct AI: Computational Thinking for Beginners*
- *Code Python, Consult AI: Python Fundamentals for the AI Era*
- *Ship Python, Orchestrate AI: Professional Python in the AI Era*
- *Converse Python, Partner AI: The Intentional Prompting Methodology*

Web Track:

- *Build Web, Guide AI: Business Web Development with AI*